



The Guardrail Catalogue

Sixty-nine techniques for governing AI agents — and what Craft A Bot does with each

The second edition of the catalogue that ships inside Craft A Bot, laid out for reading: each technique described in plain terms, categorised by what it does, rated for maturity, mapped to the threats it answers, and marked — honestly — with the product's own coverage.



EDITION 2026-10 • PENDING REVIEW

How to read this catalogue

This is the second edition of the Guardrail Catalogue that ships inside Craft A Bot: sixty-nine techniques for governing AI agents — the first edition’s forty-five, the mechanisms the code already had that no entry claimed, and what a bank’s control framework names that a survey of agent security does not — gathered from the industry’s products, the standards bodies, the regulators and the research literature, and sorted into six categories by what they do. Each entry says what the technique is in plain terms, how mature it is, which threats it answers, and — separately and without inference — what Craft A Bot actually does about it today.

What each entry shows

Name and id	The technique, and the identifier it has in the catalogue’s content (<code>packages/governance/src/catalogue</code>). Techniques, not vendors: the vendors and papers that ship or propose a technique are its sources.
Sub-category	The finer grouping within the category — an input guardrail, an action control, a monitoring measure, and so on.
Maturity	How established the technique is in practice (see below).
Points	Where in the agent loop the control decides, if it decides at all. A dash means the technique is a measure, a practice or an architecture rather than a decision in the loop.
Protects against	The OWASP threat codes the technique answers: <i>AS</i> /codes from the Top 10 for Agentic Applications (2026 edition), <i>LLM</i> codes from the Top 10 for LLM Applications 2025. A key is at the back.
In Craft A Bot	The coverage status and the note the content carries, as of the 2 October 2026 snapshot, with the work package that landed it. The build refuses a status the code cannot back.
Implemented by	The components or mechanisms in the product, in the code’s own words; file numbers refer to the design notes in <code>docs/design-day2/</code> .
Sources	At least one standard, vendor document, paper or guidance note per entry, with publisher and year.

Coverage status

Coverage says what the product does, not what the technique could do. The five statuses are mutually exclusive and the catalogue build (`checkCatalogue`) refuses an entry whose status does not match what it names — a *shipped* entry that names nothing, a *blueprint* that names an implementation, a *not applicable* with no reason.

SHIPPED	a component or a mechanism exists in Craft A Bot and the register can show what it did
CONNECTABLE	the guard shell meets a vendor's contract and a checkpoint proves it
BESPOKE	a design of record exists, built in part or as content
BLUEPRINT	described and mapped; nothing built
NOT APPLICABLE	said, with the reason

In this edition: **61 shipped**, 1 connectable, **0 bespoke**, **1 blueprint**, **6 not applicable**. All sixty-nine entries are marked *pending review*: the content awaits a reader's check against its sources, and marking an entry reviewed is a content change with a reader's name on it, never a build step.

Maturity

Widely adopted	in general commercial use; several vendors or standards ship it
Emerging	shipping from some vendors or named in recent guidance; practice still settling
Research	described in papers; little or no product implementation yet

Points in the loop

pre-think	before the bot reasons over its next turn
pre-act	before an action the bot has chosen is carried out
post-act	after an action's result comes back, before the bot reads it
stage-in	at a workflow stage's input boundary
stage-out	at a workflow stage's output boundary
group	at the group chokepoint, across all seats in an episode
egress	on an outbound network call

Contents

Runtime protection

29 ENTRIES

#	TECHNIQUE	SUB-CATEGORY	MATURITY	IN CRAFT A BOT
01	Prompt-injection classifier	Input guardrail	Widely adopted	SHIPPED
02	Jailbreak classifier	Input guardrail	Widely adopted	SHIPPED
03	Hazard and content classifier	Input guardrail	Widely adopted	SHIPPED
04	Policy-conditioned classifier	Input guardrail	Emerging	SHIPPED
05	Untrusted-content marking	Input guardrail	Emerging	SHIPPED
06	Indirect-injection defences for tool results	Input guardrail	Emerging	SHIPPED
07	Memory and context-poisoning defences	Input guardrail	Research	SHIPPED
08	PII detection and redaction	Output guardrail	Widely adopted	SHIPPED
09	Domain output rules	Output guardrail	Widely adopted	SHIPPED
10	Output-side judges and hallucination checks	Output guardrail	Widely adopted	SHIPPED
11	Structured-output validation	Output guardrail	Widely adopted	SHIPPED
12	Tool allow and deny lists	Action control	Widely adopted	SHIPPED
13	Policy-as-code decision point	Policy as code	Emerging	SHIPPED
14	Runtime enforcement rules	Policy as code	Research	SHIPPED
15	Least-privilege scopes with recorded elevation	Policy as code	Research	SHIPPED
16	Step and token budgets	Action control	Widely adopted	SHIPPED
17	Loop and no-progress detection	Action control	Widely adopted	SHIPPED
18	Rate limits	Action control	Widely adopted	NOT APPLICABLE
19	Information-flow control and taint tracking	Information flow	Research	SHIPPED
20	Monitor agents and circuit breakers	Monitoring	Emerging	SHIPPED
21	Behavioural drift and anomaly detection	Monitoring	Emerging	SHIPPED
22	Evidence tracing and execution provenance	Monitoring	Widely adopted	SHIPPED
23	Stage-boundary guards	Policy as code	Emerging	SHIPPED
24	Purpose limitation and data minimisation	Information flow	Widely adopted	SHIPPED

#	TECHNIQUE	SUB-CATEGORY	MATURITY	IN CRAFT A BOT
25	Mandatory disclosure	Output guardrail	Widely adopted	SHIPPED
26	Cost budget	Action control	Widely adopted	SHIPPED
27	Tool-argument validation	Action control	Widely adopted	SHIPPED
28	Cascade circuit breaker	Monitoring	Research	SHIPPED
29	Automated-reasoning checks on answers	Output guardrail	Emerging	CONNECTABLE

Secure by design

5 ENTRIES

#	TECHNIQUE	SUB-CATEGORY	MATURITY	IN CRAFT A BOT
30	Privilege separation and dual-LLM patterns	Privilege separation	Emerging	SHIPPED
31	Formal verification of agent policies	Formal verification	Research	BLUEPRINT
32	Guardrail frameworks	Framework	Widely adopted	NOT APPLICAB
33	Orchestrator chokepoint	Multi-agent	Widely adopted	SHIPPED
34	Guardrail gateway	Gateway	Emerging	SHIPPED

Identity and access

6 ENTRIES

#	TECHNIQUE	SUB-CATEGORY	MATURITY	IN CRAFT A BOT
35	Agent identity, delegation chains and attestation	Identity	Emerging	SHIPPED
36	Credential hygiene	Credentials	Widely adopted	SHIPPED
37	Inter-agent message authentication	Multi-agent	Emerging	SHIPPED
38	Keeping secrets out of what leaves	Credentials	Widely adopted	SHIPPED
39	Retention and deletion	Data governance	Widely adopted	NOT APPLICAB
40	Access control on the controls	Access control	Widely adopted	NOT APPLICAB

Component hardening

7 ENTRIES

#	TECHNIQUE	SUB-CATEGORY	MATURITY	IN CRAFT A BOT
41	Sandboxed tool and code execution	Isolation	Widely adopted	NOT APPLICAB
42	Egress control	Isolation	Widely adopted	SHIPPED
43	Pack, tool and cassette integrity	Supply chain	Emerging	SHIPPED
44	Fail closed and bounded waits	Resilience	Widely adopted	SHIPPED
45	Dependency failover and degraded service	Resilience	Widely adopted	SHIPPED
46	Prompt integrity	Supply chain	Emerging	SHIPPED
47	Content credentials on outputs	Provenance	Emerging	NOT APPLICAB

Evaluation and assurance

10 ENTRIES

#	TECHNIQUE	SUB-CATEGORY	MATURITY	IN CRAFT A BOT
48	Evaluation harnesses and policy-compliance benchmarks	Evaluation	Widely adopted	SHIPPED
49	Automated red-teaming	Red-teaming	Emerging	SHIPPED
50	Safety cases and transparency artefacts	Assurance	Emerging	SHIPPED
51	Incident reporting	Assurance	Widely adopted	SHIPPED
52	Control-effectiveness measurement	Assurance	Emerging	SHIPPED
53	Fairness and parity measurement	Evaluation	Widely adopted	SHIPPED
54	Governance frameworks and management systems	Framework	Widely adopted	SHIPPED
55	Calibration monitoring	Evaluation	Widely adopted	SHIPPED
56	Model inventory and change control	Assurance	Widely adopted	SHIPPED
57	Shadow running	Assurance	Widely adopted	SHIPPED

Human oversight

12 ENTRIES

#	TECHNIQUE	SUB-CATEGORY	MATURITY	IN CRAFT A BOT
58	Risk-tiered approval	Human in the loop	Widely adopted	SHIPPED
59	Four-eyes and decision-rights ceilings	Human in the loop	Widely adopted	SHIPPED
60	Kill switch and safe-mode degradation	Interruptibility	Widely adopted	SHIPPED
61	Levels of autonomy	Autonomy	Emerging	SHIPPED
62	Confirmation fatigue	Human in the loop	Research	SHIPPED
63	Explainability to end users	Explainability	Widely adopted	SHIPPED
64	Confidence gating and abstention	Human in the loop	Emerging	SHIPPED
65	Vulnerability detection and support	Customer outcomes	Widely adopted	SHIPPED
66	Contestability and appeal	Contestability	Widely adopted	SHIPPED
67	Timeliness and escalation by the clock	Escalation	Widely adopted	SHIPPED
68	Override reasons	Human in the loop	Widely adopted	SHIPPED
69	Adaptive approval	Human in the loop	Research	SHIPPED

Runtime protection

Controls that act while the bot is running — on what it reads, what it is about to do, what it says and what comes back from its tools. This is the largest group because it is where most of the industry's products sit: classifiers in front of the model, filters behind it, rules over its actions and monitors over the run — and, since the second edition, the controls a bank's own rulebook puts there: what must be said, what may be read, what a call may spend. The sub-categories say where in the loop each control decides.

Input guardrail 7 · Output guardrail 6 · Action control 6 · Policy as code 4 · Information flow 2 · Monitoring 4

01 Prompt-injection classifier

SHIPPED

prompt-injection-classifier

SUB-CATEGORY Input guardrail MATURITY Widely adopted POINTS pre-think, pre-act

A classifier over what the bot is about to read or do that flags an injected instruction.

Prompt injection is text that arrives as data — a customer message, a retrieved document, a tool result — but is written to read as an instruction to the bot ("ignore your rules and move the balance"). A prompt-injection classifier is a small model or a hosted service that scores each piece of incoming text for that pattern before the bot reasons over it or acts on it, and flags or blocks what it finds. It sits in front of every other control: if an injected instruction gets through, the rest of the stack is defending a bot that has already been redirected.

PROTECTS AGAINST ASI01 Agent goal hijack; LLM01 Prompt injection

IN CRAFT A BOT SHIPPED Five services through the shell, each with an offline stand-in; Lakera and Bedrock are harness-only connections (WP99) with their live checkpoints pending. WP42

IMPLEMENTED BY guard-local/prompt-guard; geap/model-armor; azure-content-safety/content-safety; lakera-guard/guard; bedrock-guardrails/apply-guardrail

- SOURCES
- Meta, *Llama Guard 4 and Prompt Guard 2 model cards* (2025).
 - Google Cloud, *Model Armor documentation (filter version 3)* (2026).
 - Microsoft, *Azure AI Content Safety — Prompt Shields and harm categories* (2025).
 - Lakera, *Lakera Guard documentation* (2025).
 - AWS, *Amazon Bedrock Guardrails (prompt-attack filter, automated reasoning checks)* (2025).
 - OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).
 - OWASP GenAI Security Project, *OWASP Top 10 for LLM Applications 2025* (2025).

02 Jailbreak classifier

SHIPPED

jailbreak-classifier

SUB-CATEGORY Input guardrail **MATURITY** Widely adopted **POINTS** pre-think

A classifier trained to spot attempts to override the model's own rules.

A jailbreak is an attempt to talk a model out of its own rules — a role-play framing, a fictional “developer mode”, encoded or fragmented instructions, sustained pressure over many turns. A jailbreak classifier is trained on those attempts and scores the user's turn for them before the model thinks. It overlaps with the injection classifier but targets the person talking to the bot rather than content smuggled in from elsewhere.

PROTECTS AGAINST ASI01 Agent goal hijack; LLM01 Prompt injection**IN CRAFT A BOT** **SHIPPED** Prompt Guard 2 and Model Armor's jailbreak detection; constitutional classifiers are a lab's own deployment, not a service the shell can reach. WP42**IMPLEMENTED BY** guard-local/prompt-guard ; geap/model-armor**SOURCES**

- Meta, *Llama Guard 4 and Prompt Guard 2 model cards* (2025).
- Google Cloud, *Model Armor documentation (filter version 3)* (2026).
- Anthropic, *Constitutional Classifiers: defending against universal jailbreaks* (2025).
- Microsoft, *Azure AI Content Safety — Prompt Shields and harm categories* (2025).

03 Hazard and content classifier

SHIPPED

hazard-classifier

SUB-CATEGORY Input guardrail **MATURITY** Widely adopted **POINTS** pre-think, pre-act, post-act

A classifier over a taxonomy of harms (MLCommons, Azure severities) applied to prompts and responses.

A classifier that places text in a taxonomy of harms — violence, self-harm, sexual content, hate, and categories a bank cares about such as facilitating fraud — and rates its severity. Applied on the way in and on the way out, so a bot neither reasons over nor says something in a category the deployer has excluded. The taxonomies come from MLCommons and the vendors; the thresholds are the deployer's.

PROTECTS AGAINST LLM05 Improper output handling; ASI09 Human-agent trust exploitation**IN CRAFT A BOT** **SHIPPED** Llama Guard 4 over Ollama, Azure Content Safety, and Model Armor's responsible-AI filters. WP42**IMPLEMENTED BY** guard-local/llama-guard ; azure-content-safety/content-safety ; geap/model-armor**SOURCES**

- Meta, *Llama Guard 4 and Prompt Guard 2 model cards* (2025).
- Microsoft, *Azure AI Content Safety — Prompt Shields and harm categories* (2025).
- OpenAI, *Moderation API and gpt-oss-safeguard* (2025).
- Google and IBM, *ShieldGemma and Granite Guardian model cards* (2024).
- Google Cloud, *Model Armor documentation (filter version 3)* (2026).

04 Policy-conditioned classifier

SHIPPED

policy-conditioned-classifier

SUB-CATEGORY Input guardrail **MATURITY** Emerging **POINTS** pre-think, pre-act

A safety reasoner that takes the deployer's written policy at inference time and classifies against it.

Most classifiers carry a fixed taxonomy chosen by the vendor. A policy-conditioned classifier is given the deployer's own written policy at inference time and reasons about whether a text complies with it — so a bank's rulebook, not a vendor's list, is what the check is made against. This is new (OpenAI's gpt-oss-safeguard, 2025) and untested at scale.

PROTECTS AGAINST ASI01 Agent goal hijack; ASI09 Human-agent trust exploitation

IN CRAFT A BOT **SHIPPED** policyConditionedReader is an IlmReader over any cartridge with a written rulebook as its system prompt; the bank's nine-rule rulebook (fs-bank's BANK_RULEBOOK) reads through a local general model, recorded live over the seven adversarial corpora and replayed in CI's benchmark. Fitted as a guard through readerComponent or the quarantined reader; no desk stack fits it yet. WP143

IMPLEMENTED BY reader:fs-bank/reader/policy-conditioned

SOURCES

- OpenAI, *Moderation API and gpt-oss-safeguard* (2025).

05 Untrusted-content marking

SHIPPED

untrusted-content-marking

SUB-CATEGORY Input guardrail **MATURITY** Emerging **POINTS** pre-think, post-act

Spotlighting, instruction hierarchy or a control/data split so retrieved text cannot pose as an instruction.

A language model cannot by itself tell an instruction from a quotation. Marking techniques make the boundary explicit: spotlighting wraps retrieved text in delimiters and tells the model it is data; an instruction hierarchy trains the model to rank the operator's instructions above the user's and the user's above any content; a control/data split (CaMeL) keeps untrusted text out of the planning model altogether. The aim is that a retrieved page or a tool result can inform the bot but never command it.

PROTECTS AGAINST ASI01 Agent goal hijack; ASI06 Memory and context poisoning; LLM01 Prompt injection

IN CRAFT A BOT **SHIPPED** Every tool and line answer the component names is marked untrusted at post-act and wrapped between markers in the prompt as data, never instructions; the content-is-untrusted leaf lets a card act on it. WP124

IMPLEMENTED BY governance/untrusted-content ; fs-bank/guard/quarantined-reader ;
mechanism:core/untrusted-wrap ; mechanism:desk/brief-separation

SOURCES

- Microsoft Research, *Defending against indirect prompt injection with spotlighting* (2024).
- OpenAI, *The Instruction Hierarchy: training LLMs to prioritise privileged instructions* (2024).
- Google DeepMind, *Defeating prompt injections by design (CaMeL)* (2025).

06 Indirect-injection defences for tool results

SHIPPED

indirect-injection-defence

SUB-CATEGORY Input guardrail MATURITY Emerging POINTS post-act

Treating tool output, retrieved documents and MCP descriptions as attack surface — poisoned tools, confused deputies.

Indirect injection arrives not from the person talking to the bot but through what the bot fetches: a poisoned factsheet, a note in the CRM, a doctored payslip, a tool whose description carries hidden instructions. These defences treat every tool result, retrieved document and tool description as attack surface — scanning them, checking tool descriptions against a registry, and testing the bot under such attacks so that its behaviour when it meets one is known rather than hoped for.

PROTECTS AGAINST ASI02 Tool misuse and exploitation; ASI04 Agentic supply-chain vulnerabilities; LLM01 Prompt injection

IN CRAFT A BOT **SHIPPED** Marking, taint and the quarantined reader answer a poisoned tool result — a planted SYSTEM line in a bureau answer is marked, and the call copying it blocked. A tool description edited after it was pinned is refused at registration by the pack digest (WP141, supply-chain-integrity); a poisoned description a pack ships from the start is not caught by it. WP124

IMPLEMENTED BY governance/untrusted-content ; governance/taint ; fs-bank/guard/quarantined-reader ; scenario:fs-advice/scenarios/poisoned-factsheet ; scenario:fs-fraud/scenarios/crm-note-injection ; scenario:fs-lending/scenarios/doctored-payslip ; scenario:fs-disputes/scenarios/merchant-note-injection ; policy-card:fs-fraud/policy/no-auto-release-from-instructions-in-records

SOURCES

- OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).
- Model Context Protocol, *MCP security best practices* (2025).
- MITRE, *MITRE ATLAS (agentic techniques, 2025–26 updates)* (2025).

07 Memory and context-poisoning defences

SHIPPED

memory-provenance

SUB-CATEGORY Input guardrail MATURITY Research POINTS pre-think

Provenance tags on what a bot remembers, quarantine of untrusted memory, refusal to reason over it.

A bot that remembers across turns or across cases can be poisoned once and misled for good. Memory-provenance defences tag every memory with where it came from and how trusted that source is, quarantine memory that was written from untrusted content, and refuse to let the bot reason over a memory whose provenance is unknown. Still largely a research topic; the attacks are well documented.

PROTECTS AGAINST ASI06 Memory and context poisoning

IN CRAFT A BOT **SHIPPED** A notebook write made after the bot read unquarantined untrusted content is tagged untrusted on memory.updated — the context's label, not the words'. The component refuses a think over such a notebook (or notes it), and the memory-is-untrusted leaf lets a card do the same. The label is coarse by design: a quarantined result does not taint, and a fork does not refold it. WP141

IMPLEMENTED BY governance/memory-provenance ; mechanism:core/memory-trace ; mechanism:core/memory-label

SOURCES

- arXiv, *Memory-poisoning attacks on LLM agents (2025–26 research)* (2025).
- OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).

08 PII detection and redaction

SHIPPED

pii-redaction

SUB-CATEGORY Output guardrail **MATURITY** Widely adopted **POINTS** pre-act

Finding personal identifiers in what the bot is about to say and rewriting the line before it goes out.

Before a line leaves the bot it is scanned for personal identifiers — names, account and card numbers, addresses, dates of birth — and the identifiers are masked or removed, so the outgoing text is safe to show even when the model was careless. Output-side redaction is a last line of defence for data protection, not a substitute for keeping the data out of the model’s context in the first place.

PROTECTS AGAINST LLM02 Sensitive information disclosure; ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED Model Armor’s Sensitive Data Protection through the shell, its redaction applied to the outgoing line since WP96; the PII-contained evaluator reads the redaction. WP96

IMPLEMENTED BY geap/model-armor ; mechanism:core/redact-say ; evaluator:fs-advice/pii-contained ; policy-card:fs-advice/policy/pii-stays-on-the-desk

- SOURCES**
- Microsoft, *Presidio — data protection and de-identification* (2024).
 - Google Cloud, *Model Armor documentation (filter version 3)* (2026).
 - Guardrails AI, *Guardrails AI validators and hub* (2025).

09 Domain output rules

SHIPPED

domain-output-rules

SUB-CATEGORY Output guardrail **MATURITY** Widely adopted **POINTS** pre-act

The bank’s own rulebook as output filters: no guarantee language, no tipping off, plain English, promotions wording.

The bank’s own rules for what may be said, applied as filters on the bot’s outgoing lines: no language that reads as a guarantee, no tipping off a customer about a suspicion, plain English, the required wording on a financial promotion. The rules are the regulator’s (COBS, the Consumer Duty, the Proceeds of Crime Act) written down as checks rather than left to the model’s discretion.

PROTECTS AGAINST ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED Every desk’s cards, compiled as components. WP60

IMPLEMENTED BY governance/policy-card ; policy-card:fs-advice/policy/no-guarantees ; policy-card:fs-advice/policy/risk-warning-rides-with-every-recommendation ; policy-card:fs-fraud/policy/never-tip-off ; policy-card:fs-onboarding/policy/a-hit-is-never-said ; evaluator:fs-advice/no-guarantee-language ; evaluator:fs-fraud/no-tip-off ; evaluator:fs-onboarding/hit-contained

- SOURCES**
- Financial Conduct Authority, *FCA Handbook — COBS 4 (financial promotions), COBS 9 (suitability), PRIN 2A (Consumer Duty)* (2023).
 - UK Parliament, *Proceeds of Crime Act 2002, s.333A (tipping off)* (2002).

10 Output-side judges and hallucination checks

SHIPPED

llm-as-judge

SUB-CATEGORY Output guardrail **MATURITY** Widely adopted **POINTS** post-act, stage-out, group

A second model or a validator judging an output for hazard, faithfulness or hallucination.

A second model, or a validator, reads what the bot produced and judges it: is it hazardous, is it faithful to the records it was given, does it assert something the sources do not support? A failing judgment can block the line, stop the run or raise a finding. Judges catch what pattern rules cannot, at the cost of a second model's own fallibility — so a judge is measured like any other control.

PROTECTS AGAINST LLM09 Misinformation; ASI09 Human-agent trust exploitation

IN CRAFT A BOT **SHIPPED** The rubric and hosted evaluators as judges with offline stand-ins; the breaker fits a judge at the chokepoint or a stage boundary. Bedrock's automated-reasoning checks are their own entry, automated-reasoning-checks (connectable since WP144). WP43

IMPLEMENTED BY monitor/evaluator-breaker; evaluator:fs-advice/rubric/understanding; evaluator:fs-advice/rubric/support; evaluator:fs-fraud/rubric/distressed-call; evaluator:geap/eval/rubric; evaluator:geap/eval/safety; evaluator:geap/eval/fulfillment; evaluator:evals/judge/rubric; brick-kind:workshop/monitor-judge

SOURCES

- Guardrails AI, *Guardrails AI validators and hub* (2025).
- AWS, *Amazon Bedrock Guardrails (prompt-attack filter, automated reasoning checks)* (2025).
- UK AI Security Institute, *Inspect evaluation framework* (2024).

11 Structured-output validation

SHIPPED

structured-output-validation

SUB-CATEGORY Output guardrail **MATURITY** Widely adopted **POINTS** stage-out

Every tool call and stage output validated against a schema before anything reads it.

Every tool call the bot makes and every output a workflow stage produces is checked against a declared schema before anything downstream reads it. A malformed or unexpected structure is refused at the boundary, which stops a large class of failures — and injected content hiding in a free-text field — from propagating into the next step.

PROTECTS AGAINST LLM05 Improper output handling; ASI05 Unexpected code execution

IN CRAFT A BOT **SHIPPED** A mechanism of the workflow runtime, not a component: every stage's input and output against its JSON schema. WP79

IMPLEMENTED BY mechanism:workflow/validate-against

SOURCES

- Guardrails AI, *Guardrails AI validators and hub* (2025).
- OpenAI, *Agents SDK guardrails and AgentKit* (2025).

12 Tool allow and deny lists

SHIPPED

tool-allow-deny

SUB-CATEGORY Action control **MATURITY** Widely adopted **POINTS** pre-act

What a bot may call, by name and by argument, decided before the call runs.

A declared list of what a bot may and may not call, checked by tool name and by argument before the call runs. A deny list blocks named actions outright; an allow list permits only the named ones; argument rules constrain, for example, which accounts or what amounts a payment tool may be given. The simplest expression of least privilege for an agent.

PROTECTS AGAINST ASI02 Tool misuse and exploitation; ASI05 Unexpected code execution; LLM06 Excessive agency

IN CRAFT A BOT **SHIPPED** The blocklist, the card leaves over arguments (33-...), and the Connector's scopes refusing a service-line operation it was not given. WP0

IMPLEMENTED BY governance/action-blocklist ; governance/policy-card ; guardrail:connector/tool-blocklist

- SOURCES**
- Anthropic, *Claude Code permissions and sandboxing* (2025).
 - OpenAI, *Agents SDK guardrails and AgentKit* (2025).
 - Vercel, *AI SDK — policy-based tool approvals* (2025).

13 Policy-as-code decision point

SHIPPED

policy-decision-point

SUB-CATEGORY Policy as code **MATURITY** Emerging **POINTS** pre-act , stage-in , stage-out

Externalising “may this bot do this?” to a policy engine evaluated per action.

Instead of scattering “may this bot do this?” across the code, the question is sent to a policy engine (Open Policy Agent with Rego, or Cedar) that evaluates written policy against the action, its arguments and the context, and returns a decision. Policy is then versioned, tested and reviewed on its own, apart from the bot, and the same engine can answer for a person or a rule as well as an agent.

PROTECTS AGAINST ASI02 Tool misuse and exploitation; ASI03 Identity and privilege abuse

IN CRAFT A BOT **SHIPPED** OPA through the shell with its live checkpoint taken; Cedar through Amazon Verified Permissions on the same seam (WP144), connectable with its checkpoint pending (``npm run smoke:cedar``); the policy card's predicate language is the built-in engine. WP45

IMPLEMENTED BY pdp-opa/opa ; pdp-cedar/verified-permissions ; governance/policy-card

- SOURCES**
- CNCF, *Open Policy Agent and Rego* (2024).
 - AWS, *Cedar policy language; Bedrock AgentCore gateway policies* (2025).
 - Microsoft, *Agent Governance Toolkit — OPA, Rego and Cedar policies for agents* (2025).

14 Runtime enforcement rules

SHIPPED

runtime-enforcement-dsl

SUB-CATEGORY Policy as code **MATURITY** Research **POINTS** pre-think, pre-act, post-act

Trigger → predicate → enforcement rules intercepting the agent loop (AgentSpec's shape).

A small rule language for the agent loop: on a trigger (before a think, before an action, after a result) evaluate a predicate over the current state, and apply an enforcement — allow, block, stop the run, ask a person. AgentSpec is the research statement of this shape; Progent applies it to privilege. Craft A Bot's policy cards are the same three parts.

PROTECTS AGAINST ASI01 Agent goal hijack; ASI02 Tool misuse and exploitation

IN CRAFT A BOT SHIPPED Policy cards are the AgentSpec shape: a hook, a predicate, a disposition. WP22

IMPLEMENTED BY governance/policy-card

SOURCES

- ICSE (arXiv 2503.18666), *AgentSpec: customizable runtime enforcement for safe and reliable LLM agents* (2026).
- arXiv 2504.11703, *Progent: programmable privilege control for LLM agents* (2025).

15 Least-privilege scopes with recorded elevation

SHIPPED

privilege-scopes

SUB-CATEGORY Policy as code **MATURITY** Research **POINTS** pre-act

A bot started with minimal grants, every elevation request recorded and decided.

A bot starts with the least privilege its task needs. When it needs more it asks; the request and the decision are recorded, and the elevation expires. The record is what makes an audit possible — every grant a bot ever held is explained by a request someone decided.

PROTECTS AGAINST ASI03 Identity and privilege abuse

IN CRAFT A BOT SHIPPED A bot starts with a minimal grant over the calls the component governs; a call outside it is refused, or paused for a person as an elevation, recorded as elevation.requested and elevation.resolved beside the approval pair, and granted for the rest of the run once a person says yes. The Connector's scopes are the refuse-mode instance (connector/tool-blocklist, word for word as before). Grants are per run: nothing persists a scope between runs. WP142

IMPLEMENTED BY governance/privilege-scopes; guardrail:connector/tool-blocklist

SOURCES

- arXiv 2504.11703, *Progent: programmable privilege control for LLM agents* (2025).
- OWASP GenAI Security Project, *Agentic AI — Threats and Mitigations* (2025).

16 Step and token budgets

SHIPPED

budget-cap

SUB-CATEGORY Action control MATURITY Widely adopted POINTS pre-think

A hard cap on turns and tokens so a runaway bot ends the run rather than the bill.

Hard ceilings on the turns and the tokens a run may consume. When a cap is reached the run ends with a named outcome rather than looping until the bill, or the risk, has grown. The simplest runtime control and among the most effective against a runaway agent.

PROTECTS AGAINST ASI08 Cascading failures

IN CRAFT A BOT SHIPPED OUT_OF_STEPS is the loop score; the group's token budget caps an episode, and a journey is bounded in stages and value size. WP0

IMPLEMENTED BY governance/step-budget ; governance/token-budget ; mechanism:core/group-token-budget ; mechanism:workflow/bounds

SOURCES

- LangChain, *LangGraph recursion limits and time-travel debugging* (2025).
- OpenAI, *Agents SDK guardrails and AgentKit* (2025).

17 Loop and no-progress detection

SHIPPED

loop-detection

SUB-CATEGORY Action control MATURITY Widely adopted POINTS pre-act

Refusing the same non-progress move proposed too many times running.

A bot that keeps proposing the same non-progress move — the same failed call, the same question, the same edit — is stopped after a set number of repetitions. Progress is judged by a predicate the world supplies, so the detector knows what counts as forward motion in that domain rather than guessing from the text.

PROTECTS AGAINST ASI08 Cascading failures

IN CRAFT A BOT SHIPPED The loop-breaker blocks the same non-progress call repeated; the no-progress detector (WP141) stops a run whose world has not moved for N turns, whatever was tried, reading progress from the world's state on the trace and its declared progress actions. Talk on a desk is progress (it writes the transcript); the loop-breaker holds a repeated line. WP30

IMPLEMENTED BY governance/no-repetition ; governance/no-progress

SOURCES

- LangChain, *LangGraph recursion limits and time-travel debugging* (2025).

18 Rate limits

NOT APPLICABLE

rate-limit

SUB-CATEGORY Action control MATURITY Widely adopted POINTS —

Calls per minute or per account, bounded at the gateway.

A bound on calls per minute or per account, enforced at the gateway rather than inside the bot, so that a fault or an attack cannot turn into thousands of requests. Standard in production; not applicable in a simulator, where a run has no wall clock a rate could be measured against.

PROTECTS AGAINST ASI08 Cascading failures

IN CRAFT A BOT NOT APPLICABLE Not applicable to a simulator: a run has no wall clock a rate could be measured against — the budgets are the bound, and a provider’s own limit reaches the trace as provider.retryed.

IMPLEMENTED BY —

SOURCES • OpenAI, Agents SDK guardrails and AgentKit (2025).

19 Information-flow control and taint tracking

SHIPPED

information-flow-control

SUB-CATEGORY Information flow MATURITY Research POINTS pre-act, post-act

Labels on data that follow it through the bot so a secret cannot reach an egress or a line the purpose forbids.

Labels attached to data — a classification, a purpose — follow that data as the bot works, so a secret read for one purpose cannot flow to an outbound call or into a line the purpose forbids. Full taint tracking through a model’s reasoning is research (FIDES, CaMeL); classifying every record and gating every line by purpose is the practical part that can be built today.

PROTECTS AGAINST ASI06 Memory and context poisoning; LLM02 Sensitive information disclosure

IN CRAFT A BOT SHIPPED Value taint: a call whose argument shares four words, or a long value whole, with what was marked untrusted is blocked or sent to a person; a paraphrase through the model’s reasoning is not followed. WP124

IMPLEMENTED BY governance/taint; mechanism:fs-bank/purpose-gating; mechanism:desk/record-classification

SOURCES • arXiv, FIDES: information-flow control for LLM agents (2025).
• Google DeepMind, Defeating prompt injections by design (CaMeL) (2025).
• Simon Willison, The lethal trifecta for AI agents; the dual-LLM pattern (2025).

20 Monitor agents and circuit breakers

SHIPPED

monitor-agent

SUB-CATEGORY Monitoring **MATURITY** Emerging **POINTS** group, stage-out, post-act

A second seat or an evaluator watching the run and stopping it on a named failure.

A second seat — a monitor bot or an evaluator — watches the run as it happens and can stop it on a named failure. A circuit breaker is the mechanical form: an evaluator fitted at a chokepoint that trips when its verdict fails. SHADE-Arena studies how well a monitoring model catches an agent that is quietly pursuing a different goal.

PROTECTS AGAINST ASI08 Cascading failures; ASI10 Rogue agents

IN CRAFT A BOT **SHIPPED** The breaker at the chokepoint since WP64 and at a stage boundary since WP95; the Watchbot is a brick, its rules a second seat's view of the trace. WP48

IMPLEMENTED BY monitor/evaluator-breaker; brick-kind:monitor/watchbot; mechanism:monitor/watch-rules

- SOURCES**
- Anthropic, *SHADE-Arena: evaluating sabotage and monitoring in LLM agents* (2025).
 - OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).

21 Behavioural drift and anomaly detection

SHIPPED

behavioural-drift

SUB-CATEGORY Monitoring **MATURITY** Emerging **POINTS** —

A statistic over the run series that flags a change in what the bot does before a person would.

A statistic over the series of runs — Page–Hinkley change detection is the classic — that flags when what the bot does has shifted (more refusals, more escalations, more incidents) before a person reading periodic reports would notice. Drift detection is a measure over telemetry rather than a decision in the loop, and needs a stored series to work on.

PROTECTS AGAINST ASI08 Cascading failures

IN CRAFT A BOT **SHIPPED** Page–Hinkley and the Monitor over the stored series; not a component, a fold. WP49

IMPLEMENTED BY mechanism:metrics/drift; mechanism:evals/monitor; gate:drift

- SOURCES**
- E. S. Page, *Biometrika*; agent observability guidance, *Page–Hinkley and behavioural drift detection on agent telemetry* (1954).
 - OpenTelemetry, *OpenTelemetry semantic conventions for generative AI* (2025).

22 Evidence tracing and execution provenance

SHIPPED

execution-provenance

SUB-CATEGORY Monitoring MATURITY Widely adopted POINTS —

Every prompt, decision, action and verdict as a typed event, digested, with who was behind it.

Every prompt, decision, action and verdict is a typed event on a trace, digested so it cannot be altered unnoticed, carrying the principal that was behind it. This is what turns a bot's behaviour from an anecdote into evidence a reviewer can replay, and what the EU AI Act's record-keeping articles ask for.

PROTECTS AGAINST ASI10 Rogue agents; ASI03 Identity and privilege abuse

IN CRAFT A BOT SHIPPED Hard rule 3: everything observable arrives as an event. WP0

IMPLEMENTED BY mechanism:core/trace ; mechanism:core/principal ; mechanism:governance/otel ; mechanism:workflow/handoff

- SOURCES
- OpenTelemetry, *OpenTelemetry semantic conventions for generative AI* (2025).
 - Arize, *OpenInference — GUARDRAIL and agent spans* (2025).
 - European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 9, 12, 13 and 14* (2024).

23 Stage-boundary guards

SHIPPED

stage-boundary-guard

SUB-CATEGORY Policy as code MATURITY Emerging POINTS stage-in , stage-out

A guard that decides at a stage's input or output whatever the executor — a rule, a person or a bot.

In a multi-stage workflow the guard decides at a stage's input or output — whatever executed the stage: a rule, a person or a bot. Guarding the boundary rather than the executor makes the check independent of who did the work, and lets a human stage be held to the same output contract as an automated one.

PROTECTS AGAINST ASI02 Tool misuse and exploitation; ASI08 Cascading failures

IN CRAFT A BOT SHIPPED The workflow runtime's boundary chain (69-... §10). Since WP137 every shipped journey holds its irreversible stage at its input with a gate on the desk's case file — the desk's own predicates over its state, never the truth. No stage-out breaker is fitted by default: the stage's own trace is too narrow for a process evaluator, and a truth-reading one would know the answer. WP95

IMPLEMENTED BY governance/policy-card ; monitor/evaluator-breaker ; geap/model-armor ; mechanism:workflow/boundary-chain ; policy-card:fs-lending/policy/disbursement-waits-for-the-file ; policy-card:fs-advice/policy/execution-waits-for-the-file ; policy-card:fs-advice/policy/redress-waits-for-the-file ; policy-card:fs-fraud/policy/sar-waits-for-the-file ; policy-card:fs-onboarding/policy/open-waits-for-the-file ; policy-card:fs-disputes/policy/reimbursement-waits-for-the-file ; policy-card:fs-collections/policy/agreement-waits-for-the-file ; policy-card:fs-servicing/policy/closure-waits-for-the-file

- SOURCES
- ICSE (arXiv 2503.18666), *AgentSpec: customizable runtime enforcement for safe and reliable LLM agents* (2026).
 - OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).

24 Purpose limitation and data minimisation

SHIPPED

data-minimisation

SUB-CATEGORY Information flow **MATURITY** Widely adopted **POINTS** pre-act

A bot reads only what its purpose needs; a special-category record is read for its declared purpose or not at all.

UK GDPR's purpose-limitation and data-minimisation principles, applied to a bot: it reads only the records its declared purpose needs, and a special-category record — health, a protected characteristic — is read for the purpose that justifies it or not at all. In practice every lookup is gated by purpose, every record carries a classification, and an evaluator afterwards scores what was actually read against what the task required. The ICO's guidance on AI treats this as the first question of a data-protection impact assessment; a bot that can see the whole customer file is a finding before it has said a word.

PROTECTS AGAINST LLM02 Sensitive information disclosure; ASI06 Memory and context poisoning

IN CRAFT A BOT SHIPPED Every bank line is purpose-gated and a special-category record never enters the context ladder; the card refuses a lookup outside the purpose and the evaluator scores what was read. WP59

IMPLEMENTED BY mechanism:fs-bank/purpose-gating; mechanism:desk/record-classification; policy-card:fs-advice/policy/purpose-limited-lookup; evaluator:fs-advice/data-minimised

- SOURCES**
- UK Parliament (Data Protection Act 2018 and the retained Regulation), *UK GDPR, Articles 5 (principles), 22 (automated decisions) and 25 (by design)* (2018).
 - Information Commissioner's Office, *Guidance on AI and data protection* (2023).

25

Mandatory disclosure

SHIPPED

mandatory-disclosure

SUB-CATEGORY

Output guardrail

MATURITY

Widely adopted

POINTS

pre-act

What a customer must be told – a risk warning, a scam warning, what a plan asks of them – said, and recorded as said.

Some things a customer must be told, in words the regulator has shaped: CONC 7’s pointer to free debt advice when a plan is agreed, COBS 4’s risk warning on an investment, the PSR’s APP-scram reimbursement rights, the Ombudsman in every final response under DISP. The control registers each disclosure with its exact wording and the obligation it serves, binds it to the customer-facing action that reaches that moment so it cannot be skipped, and records on the trace that it was said and what was said. The Consumer Duty’s consumer-understanding outcome asks for exactly this evidence — not that a warning existed somewhere, but that this customer received it.

PROTECTS AGAINST

ASI09

Human-agent trust exploitation

IN CRAFT A BOT

SHIPPED

The bank’s disclosures are registered with their exact wording and the obligations they cite (fs-bank’s DISCLOSURES): CONC 7’s debt advice, COBS 4’s risk warning, PSR APP reimbursement rights, a lending review right, DISP’s Ombudsman (WP145). The customer-facing action that reaches the moment makes the disclosure itself, so it cannot be skipped, and the trace carries disclosure.given with the digest of the words said; an evaluator per desk holds each run to it. Diverged: no card blocks a decision until the disclosure is made — the action that makes the decision makes the disclosure, so a card would guard nothing.

IMPLEMENTED BY

mechanism:core/disclosure ; trace-guarantee:disclosure.given ; evaluator:fs-advice/risk-warning-disclosed ; evaluator:fs-collections/debt-advice-disclosed ; evaluator:fs-disputes/reimbursement-rights-disclosed ; evaluator:fs-lending/review-right-disclosed ; evaluator:fs-advice/ombudsman-disclosed ; policy-card:fs-advice/policy/risk-warning-rides-with-every-recommendation ; evaluator:fs-advice/warning-given ; evaluator:fs-fraud/scam-warning-given

SOURCES

- Financial Conduct Authority, *FCA Handbook — COBS 4 (financial promotions) and COBS 9 (suitability)* (2023).
- Financial Conduct Authority, *FCA Handbook — CONC 5 (creditworthiness) and CONC 7 (arrears, default and recovery)* (2023).
- Payment Systems Regulator, *Specific Requirement 1 — APP scam reimbursement* (2024).

26 Cost budget

SHIPPED

cost-cap

SUB-CATEGORY Action control **MATURITY** Widely adopted **POINTS** pre-think

A cap on what a run or a campaign may spend, in money, before it stops.

A ceiling on what a run, or a whole campaign, may spend in money before it stops — tokens priced at the provider's list rates with the source of those prices stated. The token budget bounds volume; the cost cap bounds the bill, which is what a finance function and OWASP's unbounded-consumption entry actually care about. A looping or hijacked agent on a metered model is an operational loss as much as a safety event, and a cap turns it into a named outcome with a known maximum.

PROTECTS AGAINST LLM10 Unbounded consumption; ASI08 Cascading failures

IN CRAFT A BOT SHIPPED governance/cost-cap stops a run before a turn once its tokens, at the list prices its config states with their source, have spent the cap in dollars (WP148); the token budget caps tokens. A price enters only with its source, so no shipped stack fits the cap with a price: it is a component a deployer configures. WP148

IMPLEMENTED BY governance/cost-cap ; governance/token-budget

SOURCES

- OWASP GenAI Security Project, *OWASP Top 10 for LLM Applications 2025* (2025).

27 Tool-argument validation

SHIPPED

tool-argument-validation

SUB-CATEGORY Action control **MATURITY** Widely adopted **POINTS** pre-act

Every tool call's arguments checked against the tool's declared parameters before it runs, a malformed call refused as a verdict.

Before a tool call runs, its arguments are checked against the parameters the tool declared — type, required fields, allowed values, the shape of a list — and a call that does not fit is refused as a verdict rather than left for the tool to fail on. A model emits malformed calls more often than a programmer would expect, and an attacker can plant arguments that look plausible to the model but not to a schema. Validating at the boundary makes the refusal visible on the trace and keeps a bad call from reaching a system that might partially honour it. OWASP lists it under improper output handling and tool misuse.

PROTECTS AGAINST LLM05 Improper output handling; ASI02 Tool misuse and exploitation

IN CRAFT A BOT SHIPPED governance/tool-argument-validation checks a proposed world action's arguments against the schema its world declares — type, required, properties, enum, items — and refuses one that does not fit at pre-act, so the world's own refusal becomes a verdict on the trace before the world sees the call (WP148). Tools are not checked: a component sees the world's actions, not the registry's tools. WP148

IMPLEMENTED BY governance/tool-argument-validation

SOURCES

- OWASP GenAI Security Project, *OWASP Top 10 for LLM Applications 2025* (2025).
- OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).

28 Cascade circuit breaker

SHIPPED

cascade-breaker

SUB-CATEGORY Monitoring MATURITY Research POINTS group

An episode stopped after a set number of refusals or a named failure, before one seat's fault spreads to the rest.

In a multi-agent episode one seat's fault — a bot that has been hijacked, is looping, or keeps proposing refused actions — can spread to every seat that trusts it. A cascade breaker watches the episode as a whole and stops it after a set number of refusals or on a named evaluator failure, before the fault propagates. It is the stability pattern from Release It! applied to agents rather than services, and it answers OWASP's cascading-failures threat directly: contain the first failure and the second never happens.

PROTECTS AGAINST ASI08 Cascading failures

IN CRAFT A BOT **SHIPPED** The group circuit breaker stops an episode at its refusal limit; the evaluator breaker stops one on a named evaluator failure. WP48

IMPLEMENTED BY monitor/evaluator-breaker ; mechanism:monitor/group-circuit-breaker

SOURCES

- OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).
- M. Nygard (Pragmatic Bookshelf, 2nd edition), *Release It! — stability patterns: timeouts, circuit breakers, fail fast* (2018).

29 Automated-reasoning checks on answers

CONNECTABLE

automated-reasoning-checks

SUB-CATEGORY Output guardrail MATURITY Emerging POINTS pre-act

What the bot is about to say translated to logic and checked against rules written as logic: proved, contradicted, or left open.

Rather than ask a second model whether an answer is right, translate the answer into logic and check it against rules written as logic — a policy on what a product allows, what a limit is, who is eligible — and report each claim as proved, contradicted, or beyond what the checker could translate. Amazon Bedrock's automated-reasoning checks are the commercial form; the appeal to a bank is that a contradiction is a mathematical finding, not an opinion. The limits are real: the policy must be written as logic first, and a claim the checker cannot translate is an open question, never a pass.

PROTECTS AGAINST LLM09 Misinformation

IN CRAFT A BOT **CONNECTABLE** Connectable, checkpoint pending (WP144) — the first entry with the status: the adapter reads ApplyGuardrail's automated-reasoning findings (a contradicted claim is a violation; one the checker could not translate is partial, never an allow), its stand-in runs in CI, and no live answer has been taken (`npm run smoke:bedrock-ar` with an account and a policy). Formal verification of a whole policy stays a blueprint. WP144

IMPLEMENTED BY bedrock-guardrails/automated-reasoning

SOURCES

- AWS, *Amazon Bedrock Guardrails — automated reasoning checks* (2025).

Secure by design

Architectural choices that remove a class of attack rather than detect it: keeping untrusted text away from the model that holds the tools, proving a policy rather than checking each action, one chokepoint for every seat of a multi-agent episode, a gateway that guards the wire whoever wrote the agent, and the frameworks that package rails around a model.

Privilege separation 1 · Formal verification 1 · Framework 1 · Multi-agent 1 · Gateway 1

30 Privilege separation and dual-LLM patterns

SHIPPED

privilege-separation

SUB-CATEGORY Privilege separation MATURITY Emerging POINTS group

A privileged planner that never reads untrusted content and a quarantined reader that never acts.

The dual-LLM pattern: a privileged planner that never reads untrusted content, and a quarantined reader that reads it but cannot act. Untrusted text therefore never reaches the model that holds the tools. CaMeL formalises this with a capability system over what the reader may hand back; AirGapAgent applies the same idea to private data. An architecture, not a filter — it removes the attack instead of detecting it.

PROTECTS AGAINST ASI01 Agent goal hijack; ASI07 Insecure inter-agent communication

IN CRAFT A BOT SHIPPED The quarantined reader alone reads untrusted content, asked with nothing to act with, and the acting seat reads its typed answers instead; the Watchbot is a second seat with its own brain. WP124

IMPLEMENTED BY fs-bank/guard/quarantined-reader; mechanism:core/group-chokepoint

SOURCES

- Simon Willison, *The lethal trifecta for AI agents; the dual-LLM pattern* (2025).
- Google DeepMind, *Defeating prompt injections by design (CaMeL)* (2025).
- arXiv, *AirGapAgent: protecting privacy with context hijacking* (2024).

31 Formal verification of agent policies

BLUEPRINT

formal-verification

SUB-CATEGORY Formal verification MATURITY Research POINTS —

Proving a policy holds over the agent’s possible actions rather than checking each one.

Rather than checking each action as it comes, prove that a policy holds over every action a bot could take — for example that no path leads to a payment without an approval. Research today (ShieldAgent); Amazon Bedrock’s automated-reasoning checks are the nearest commercial form, and are aimed at factual policy compliance rather than agent actions.

PROTECTS AGAINST ASI02 Tool misuse and exploitation

IN CRAFT A BOT BLUEPRINT Recorded as research: proving a policy over every possible action is not built. Bedrock’s automated-reasoning checks, which check one answer’s claims against rules as logic, are their own entry (automated-reasoning-checks, connectable since WP144).

IMPLEMENTED BY —

SOURCES

- arXiv, *ShieldAgent: shielding agents via verifiable safety policy reasoning* (2025).
- AWS, *Amazon Bedrock Guardrails (prompt-attack filter, automated reasoning checks)* (2025).

32 Guardrail frameworks

NOT APPLICABLE

guardrail-framework

SUB-CATEGORY Framework MATURITY Widely adopted POINTS pre-think, pre-act, post-act

Programmable rails (NeMo, Guardrails AI) wrapping a model’s input and output.

Programmable rails — NVIDIA NeMo Guardrails, Guardrails AI, the OpenAI Agents SDK — that wrap a model’s input and output with validators, dialogue flows and hooks. Useful as a dependency for a team building from scratch; Craft A Bot has its own guard shell and component contract, and treats a vendor’s validators as services it can reach rather than as rails it runs inside.

PROTECTS AGAINST LLM01 Prompt injection; LLM05 Improper output handling

IN CRAFT A BOT NOT APPLICABLE Not applicable as a dependency: the guard shell (29-...) and the component contract (85-...) are the product’s own framework; a vendor framework’s validators reach it as a service, not as rails.

IMPLEMENTED BY —

SOURCES

- NVIDIA, *NeMo Guardrails* (2024).
- Guardrails AI, *Guardrails AI validators and hub* (2025).
- OpenAI, *Agents SDK guardrails and AgentKit* (2025).

33 Orchestrator chokepoint

SHIPPED

orchestrator-chokepoint

SUB-CATEGORY Multi-agent MATURITY Widely adopted POINTS group

Every seat of a multi-agent episode acting through one chain, where the supervisor's guards and observers sit.

When several bots act in one episode, every seat's proposed action goes through a single chain — the supervisor's — where the shared budget, the observers and the breakers sit. Without it each seat carries its own guards and an attacker, or a fault, only needs the weakest. The chokepoint is the multi-agent form of a control plane: one place to look, one place to stop, one budget for the episode. The multi-agency guidance on agentic AI and OWASP's inter-agent and cascading-failure entries both point here.

PROTECTS AGAINST ASI07 Insecure inter-agent communication; ASI08 Cascading failures

IN CRAFT A BOT SHIPPED The session group runs every seat's actions through one chain with the group's budget, observers and breakers. WP29

IMPLEMENTED BY monitor/evaluator-breaker ; mechanism:core/group-chokepoint ; mechanism:core/group-token-budget

- SOURCES
- OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).
 - CISA and partner agencies, *Multi-agency guidance on securing agentic AI* (2026).

34 Guardrail gateway

SHIPPED

guardrail-gateway

SUB-CATEGORY Gateway MATURITY Emerging POINTS pre-think, pre-act, post-act

A proxy in front of any agent's model traffic that runs the guards on the wire, whoever wrote the agent.

A proxy placed between any agent and its model provider that runs the guards on the wire itself — over the prompts going up and the completions coming back — so the agent's author need not have built any of them in. It is how a bank governs an agent it bought, or one a team wrote without the platform: the gateway holds the stack, the policy and the trace, and the agent only sees a model endpoint. Bedrock AgentCore's gateway policies and Microsoft's agent-governance toolkit are the vendors' versions; the pattern is the same as an API gateway in front of a microservice.

PROTECTS AGAINST ASI01 Agent goal hijack; ASI02 Tool misuse and exploitation

IN CRAFT A BOT SHIPPED The Gate runs a saved stack over the chat-completions wire, loopback-bound with one upstream host; a reference implementation, not a product. WP127

IMPLEMENTED BY mechanism:gate/enforce ; mechanism:gate/loopback

- SOURCES
- AWS, *Cedar policy language; Bedrock AgentCore gateway policies* (2025).
 - Microsoft, *Agent Governance Toolkit — OPA, Rego and Cedar policies for agents* (2025).

Identity and access

Who the bot is, whose authority it acts under, and how it proves it — to a directory, to another agent, and on the trace — and the housekeeping around it: secrets kept out of what leaves, records kept no longer than needed, and who may change a control. The same questions a bank asks of a member of staff, asked of an agent.

Identity 1 · Credentials 2 · Multi-agent 1 · Data governance 1 · Access control 1

35 Agent identity, delegation chains and attestation

SHIPPED

agent-identity

SUB-CATEGORY Identity MATURITY Emerging POINTS —

A bot as an auditable principal acting on behalf of a person, every action attested with what let it through.

A bot as an auditable principal: it has an identity of its own, acts on behalf of a named person, and every action is attested with what let it through — the grant, the approval, the delegation chain. Microsoft Entra Agent ID, Okta's Cross App Access and SPIFFE are the industry's moves to give agents identities a directory can manage and revoke.

PROTECTS AGAINST ASI03 Identity and privilege abuse; ASI10 Rogue agents

IN CRAFT A BOT SHIPPED On the trace when the host names one; no directory integration. WP65

IMPLEMENTED BY mechanism:core/principal; trace-guarantee:action.performed

- SOURCES
- Microsoft, *Microsoft Entra Agent ID* (2025).
 - Okta, *Cross App Access (XAA) and OAuth extensions for agents* (2025).
 - CNCF, *SPIFFE/SPIRE workload identity* (2024).

36 Credential hygiene

SHIPPED

credential-hygiene

SUB-CATEGORY Credentials MATURITY Widely adopted POINTS —

Keys in a vault, read at call time, never in a file, a trace or a URL, with a test that proves it.

Keys live in a vault and are read at call time; they are never written to a file, never appear on the trace, never travel in a URL — and a test proves that no key can leak into an artefact. Basic, and the control most often found broken when agents are wired to real systems.

PROTECTS AGAINST ASI03 Identity and privilege abuse; LLM02 Sensitive information disclosure

IN CRAFT A BOT SHIPPED Hard rule 2. WP0

IMPLEMENTED BY mechanism:core/key-vault; mechanism:core/key-leak-test; mechanism:core/export-scrub

- SOURCES
- CISA and partner agencies, *Multi-agency guidance on securing agentic AI* (2026).
 - Model Context Protocol, *MCP security best practices* (2025).

37 Inter-agent message authentication

SHIPPED

inter-agent-authentication

SUB-CATEGORY Multi-agent MATURITY Emerging POINTS pre-think

A message from another agent verified before it is trusted.

When bots talk to bots, a message from another agent is verified — who sent it, that it was not altered in transit — before it is trusted. The attack is an impostor agent on the channel (the party-line scenario); the Agent2Agent protocol is where the industry is placing the authentication.

PROTECTS AGAINST **ASI07** Insecure inter-agent communication

IN CRAFT A BOT **SHIPPED** Every Radio message a seat sends carries a digest over its sender, channel, words and tick, stamped by the room; governance/peer-auth at pre-think verifies each message in view — the sender is a seat, the digest matches — and stops (or notes) one that is not, so a message under a teammate's name that no seat sent never reaches the bot's reasoning (the party line's test). Integrity over the engine's attribution, not a cryptographic signature: between separate processes it needs keys (signed agent cards, mutual TLS). Hearing stays unattributed by design. WP143

IMPLEMENTED BY governance/peer-auth ; scenario:starter/scenarios/party-line

- SOURCES
- Google and the Linux Foundation, *Agent2Agent (A2A) protocol* (2025).
 - OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).

38 Keeping secrets out of what leaves

SHIPPED

secret-scan

SUB-CATEGORY Credentials MATURITY Widely adopted POINTS —

Keys and credentials scrubbed from anything that leaves — exports, traces, logs, what a bot says — and a test that proves it.

Keys and credentials are scrubbed from everything that leaves the system — exports, traces, logs, and what the bot itself says or sends — and a test proves no key can reach a record. The outbound half is the newer part: a bot that has read a secret, or had one planted in a document, will cheerfully repeat it, so a scan over its outgoing lines and calls refuses anything shaped like a key, a token or a private key. GitHub's push protection is the familiar model; OWASP files the risk under sensitive-information disclosure.

PROTECTS AGAINST **LLM02** Sensitive information disclosure

IN CRAFT A BOT **SHIPPED** Every export passes an exact-match scrub of the vault's keys, and CI proves none reaches a record; governance/secret-scan refuses a call that would say or send something shaped like a key, token or private key (WP149) — a bot is never given a secret to say, so it answers a planted one. WP4

IMPLEMENTED BY governance/secret-scan ; mechanism:core/export-scrub ; mechanism:core/key-leak-test

- SOURCES
- GitHub, *Secret scanning and push protection* (2024).
 - OWASP GenAI Security Project, *OWASP Top 10 for LLM Applications 2025* (2025).

39 Retention and deletion

NOT APPLICABLE

data-retention

SUB-CATEGORY Data governance **MATURITY** Widely adopted **POINTS** —

Records kept only as long as their purpose needs, then deleted on a schedule.

Records are kept only as long as the purpose that justified them lasts, then deleted on a schedule that is written down and followed — UK GDPR’s storage-limitation principle. For a bot this covers the traces, the transcripts and the memory it accumulates, all of which contain personal data and all of which are easy to keep forever by default. A retention control names a period per record kind, deletes on it, and can show that it did; the ICO expects the period to be justified, not merely stated.

PROTECTS AGAINST LLM02 Sensitive information disclosure

IN CRAFT A BOT NOT APPLICABLE Not applicable: the product is local-first and retains nothing on anyone’s behalf — every record is synthetic and stays in the user’s own browser or folder until they delete it.

IMPLEMENTED BY —

SOURCES

- UK Parliament (Data Protection Act 2018 and the retained Regulation), *UK GDPR, Articles 5 (principles), 22 (automated decisions) and 25 (by design)* (2018).

40 Access control on the controls

NOT APPLICABLE

configuration-access-control

SUB-CATEGORY Access control **MATURITY** Widely adopted **POINTS** —

Who may change a guard, a threshold or a stack, enforced by role.

Who may change a guard, a threshold, a stack or an approval mode, enforced by role rather than by convention — and a record of every change. A control that anyone on the team can loosen is not a control, and a bank’s change-management obligations (NIST’s CM-3, PRA SS1/23’s change control) apply to a guardrail configuration as they do to a model. In a multi-tenant platform this is a permission system; the minimum anywhere is that a change to a control is authorised by someone entitled to make it and visible afterwards.

PROTECTS AGAINST ASI03 Identity and privilege abuse

IN CRAFT A BOT NOT APPLICABLE Not applicable: there is no tenancy — one person runs the toolkit on their own machine; a change to a control is recorded (readings, the principal), never authorised.

IMPLEMENTED BY —

SOURCES

- NIST, *SP 800-53 Rev. 5 — Security and privacy controls (AC-6 least privilege, CM-3 change control, SC-24 fail in known state)* (2020).

Component hardening

Containing what a bot can reach and what happens when a part of it fails: where its code runs, where its network calls may go, whether the parts it is built from — the prompt included — are what they claim to be, what a check that cannot run does, what a dead dependency falls back to, and whether what comes out carries its provenance.

Isolation 2 · Supply chain 2 · Resilience 2 · Provenance 1

41 Sandboxed tool and code execution

NOT APPLICABLE

sandboxed-execution

SUB-CATEGORY Isolation MATURITY Widely adopted POINTS —

Running agent-generated code in a disposable microVM or userspace kernel with no ambient credentials.

Code a bot writes or runs executes in a disposable microVM or a userspace kernel with no ambient credentials, so that a mistake or an injection cannot reach the host or the network. Standard for coding agents (E2B, Daytona, Claude Code’s sandbox); not applicable in Craft A Bot, whose bots perform declared actions on a simulated world and run no code.

PROTECTS AGAINST ASI05 Unexpected code execution

IN CRAFT A BOT NOT APPLICABLE Not applicable: the world is the sandbox — a bot performs declared actions on a simulated world and runs no code; recorded so the claim is not implied.

IMPLEMENTED BY —

- SOURCES
- AWS, Google and the sandbox vendors, *Firecracker microVMs and gVisor for agent code execution (E2B, Daytona)* (2025).
 - Anthropic, *Claude Code permissions and sandboxing* (2025).

42 Egress control

SHIPPED

egress-control

SUB-CATEGORY Isolation **MATURITY** Widely adopted **POINTS** egress

Every outbound call from a bot's bricks and provider allowed only to a declared host, or refused and recorded.

Every outbound network call from a bot's tools and its model provider is allowed only to a declared host; anything else is refused and the refusal is recorded. This closes the exfiltration leg of the "lethal trifecta" — private data, untrusted content, and a way to send data out — and is the control the multi-agency guidance puts first.

PROTECTS AGAINST ASI04 Agentic supply-chain vulnerabilities; LLM02 Sensitive information disclosure

IN CRAFT A BOT **SHIPPED** The session's fetch guard as two components; a refusal is an error on the trace. WP41

IMPLEMENTED BY governance/egress-declared; governance/egress-none

- SOURCES**
- Anthropic, *Claude Code permissions and sandboxing* (2025).
 - CISA and partner agencies, *Multi-agency guidance on securing agentic AI* (2026).

43 Pack, tool and cassette integrity

SHIPPED

supply-chain-integrity

SUB-CATEGORY Supply chain **MATURITY** Emerging **POINTS** —

What a bot is built from — packs, tools, recorded lines — declared, versioned and digested.

What a bot is built from — packs, tools, models, recorded lines — is declared, versioned and digested, so a change is visible and a tampered component is refused at load. The AI counterpart of a software bill of materials (CycloneDX's AI/ML BOM) and of content credentials (C2PA).

PROTECTS AGAINST ASI04 Agentic supply-chain vulnerabilities

IN CRAFT A BOT **SHIPPED** Every pack carries a content digest over its tool, action and sense descriptions, cards and stacks (WP141); the harness pins every shipped pack in packs.lock.json and the registry refuses one that differs — a poisoned tool description fails registration, and a stale lock fails CI. Code is not digested (a changed function is a version). The Workbench does not pin yet. WP52

IMPLEMENTED BY mechanism:core/kit-requires; mechanism:core/cassette-digest; mechanism:core/agent-card; mechanism:core/pack-digest; artefact:agent-card

- SOURCES**
- OWASP CycloneDX, *CycloneDX AI/ML bill of materials* (2024).
 - Coalition for Content Provenance and Authenticity, *C2PA content credentials specification* (2024).
 - OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025).

44 Fail closed and bounded waits

SHIPPED

fail-closed

SUB-CATEGORY Resilience **MATURITY** Widely adopted **POINTS** pre-think, pre-act, post-act

A check that cannot run stops the action rather than letting it through, and no call waits forever.

When a check cannot run — the guard service is down, the classifier times out, the policy engine does not answer — the action it was guarding is stopped, not waved through; and no call waits forever, because every dependency has a timeout. The opposite default, fail open, means a bot is least protected exactly when its infrastructure is degraded, which is also when an attacker is most interested. NIST's SC-24 (fail in a known state) and the stability patterns in Release It! are the references; the multi-agency guidance on agentic AI names it as a baseline.

PROTECTS AGAINST ASI08 Cascading failures

IN CRAFT A BOT **SHIPPED** A guard service that cannot answer stops the run with the cause could-not-check unless its config says otherwise; every provider call has a timeout. WP39

IMPLEMENTED BY mechanism:hosted/fail-closed; mechanism:hosted/hook-clamp; mechanism:core/request-timeout

- SOURCES**
- NIST, *SP 800-53 Rev. 5 — Security and privacy controls (AC-6 least privilege, CM-3 change control, SC-24 fail in known state)* (2020).
 - M. Nygard (Pragmatic Bookshelf, 2nd edition), *Release It! — stability patterns: timeouts, circuit breakers, fail fast* (2018).
 - CISA and partner agencies, *Multi-agency guidance on securing agentic AI* (2026).

45 Dependency failover and degraded service

SHIPPED

dependency-failover

SUB-CATEGORY Resilience **MATURITY** Widely adopted **POINTS** pre-think

When a model or a line fails, the bot falls back to another or to a plain sentence, inside a stated tolerance.

When a model provider or a service line fails, the bot moves to a second provider or falls back to a plain, safe sentence — and the fallback is itself within a stated tolerance, told to the customer plainly, and recorded as what happened. PRA SS1/21 asks a bank to set impact tolerances for its important business services and to show it stays inside them when a supplier fails; DORA asks the same of ICT third parties. For an agent the questions are which provider is second, what the bot says while neither is up, and whether a degraded answer is ever presented as a confident one.

PROTECTS AGAINST ASI08 Cascading failures

IN CRAFT A BOT **SHIPPED** core's failoverProvider asks each of several providers in turn on an unavailable, slow or rate-limited answer, and says on think.completed who served and who failed (WP148) — the DGX pack's two units, generalised. A faulted provider is still an injection the incident decks judge, and the Fallback card tells the customer plainly. Diverged: a provider wrapper, not a guard component — failover is not a verdict. Not done: no shipped bot names a provider list; a host builds one. WP148

IMPLEMENTED BY mechanism:core/failover; mechanism:core/provider-fault; policy-card:fs-bank/policy/fallback; evaluator:fs-bank/told-plainly

- SOURCES**
- Prudential Regulation Authority, *SS1/21 — Operational resilience: impact tolerances for important business services* (2021).
 - European Union, *Regulation (EU) 2022/2554 — the Digital Operational Resilience Act* (2022).
 - M. Nygard (Pragmatic Bookshelf, 2nd edition), *Release It! — stability patterns: timeouts, circuit breakers, fail fast* (2018).

46 Prompt integrity

SHIPPED

prompt-integrity

SUB-CATEGORY Supply chain MATURITY Emerging POINTS —

The system prompt and brief a bot runs with digested and compared with the ones that were validated.

The system prompt and the brief a bot runs with are what was validated, and not something edited since — checked by digesting the validated prompt and comparing each turn's against it. A prompt is configuration that behaves like code, and it is the easiest component to change quietly: a word added to a brief can remove a refusal, and nothing in the model's output says so. OWASP files the exposure under system-prompt leakage and supply chain; the control is the same as a checksum on a deployed binary.

PROTECTS AGAINST LLM07 System prompt leakage; ASI04 Agentic supply-chain vulnerabilities

IN CRAFT A BOT SHIPPED governance/prompt-integrity compares a turn's system prompt with the digest it was validated at and stops the run, or notes it, when they differ (WP149); the build digest (WP147) moves when the personality does, and a changed prompt misses its cassette. WP149

IMPLEMENTED BY governance/prompt-integrity ; mechanism:core/cassette-digest ; mechanism:core/build-digest

SOURCES • OWASP GenAI Security Project, OWASP Top 10 for LLM Applications 2025 (2025).

47 Content credentials on outputs

NOT APPLICABLE

output-content-provenance

SUB-CATEGORY Provenance MATURITY Emerging POINTS —

Signed provenance on generated media so a reader can tell what made it.

Signed provenance attached to generated media — an image, a document, a voice — so a reader can tell what made it, from what, and whether it has been altered. The C2PA content-credentials specification is the standard, adopted by the camera makers and the large model providers. It is a control on what a bot produces rather than on what it decides, and matters where a bank's bot generates letters, statements or marketing that a customer might later be shown a forged version of; for a bot that only says text, the digested trace does the same work.

PROTECTS AGAINST ASI09 Human-agent trust exploitation

IN CRAFT A BOT NOT APPLICABLE Not applicable: a bot here says text to a simulated customer and makes no media; what it said is on the digested trace instead.

IMPLEMENTED BY —

SOURCES • Coalition for Content Provenance and Authenticity, C2PA content credentials specification (2024).

Evaluation and assurance

How a bank comes to know, rather than believe, that its controls work: harnesses and benchmarks, red-teaming, safety cases, incident records, control-effectiveness experiments, fairness and calibration measurement, change control over what runs, shadow running before trust, and the management-system standards that give all of this a shared vocabulary.

Evaluation 3 · Red-teaming 1 · Assurance 5 · Framework 1

48

Evaluation harnesses and policy-compliance benchmarks

eval-harness

SHIPPED

SUB-CATEGORY

Evaluation

MATURITY

Widely adopted

POINTS

—

Running a bot over a matrix of scenarios, guards and seeds and gating on what it did.

Running a bot over a matrix of scenarios, guard configurations and random seeds, and gating a release on what it did. The UK AI Security Institute's Inspect and Sierra's τ -bench are the reference frameworks; the point is repeatable, comparable evidence rather than a demonstration.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT

SHIPPED

 Campaigns in CI on every push. WP38

IMPLEMENTED BY

mechanism:evals/campaign

;

mechanism:evals/evaluators

;

mechanism:evals/benchmark

;

gate:outcome-rate

;

gate:evaluator-pass-rate

SOURCES

- UK AI Security Institute, *Inspect evaluation framework* (2024).
- Sierra (arXiv), *τ -bench: a benchmark for tool-agent-user interaction* (2024).

49 Automated red-teaming

SHIPPED

automated-red-teaming

SUB-CATEGORY Red-teaming MATURITY Emerging POINTS —

An adversary that probes a bot at scale and records what got through.

An adversary — scripted, or a model playing one — that probes the bot at scale with attacks and records which got through. Anthropic’s Petri automates the auditing; SHADE-Arena tests sabotage and its detection. Red-teaming finds what a harness of well-behaved scenarios never will.

PROTECTS AGAINST ASI01 Agent goal hijack; ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED The scripted adversary, and since WP124 the red-team seat: a counterpart speaking only attack rows of a desk’s adversarial corpus; a live red-team persona remains a configuration. WP38

IMPLEMENTED BY governance/red-team-seat; mechanism:evals/adversary

- SOURCES
- Anthropic, *Petri: automated auditing of model behaviour* (2025).
 - Anthropic, *SHADE-Arena: evaluating sabotage and monitoring in LLM agents* (2025).

50 Safety cases and transparency artefacts

SHIPPED

safety-case

SUB-CATEGORY Assurance MATURITY Emerging POINTS —

A structured argument, with evidence, that a system is safe enough for its use — and the cards that describe it.

A structured argument, with the evidence attached, that a system is safe enough for its intended use — together with the transparency artefacts (model cards, system cards, an inventory entry) that describe it. The form a regulator, an internal audit function or a model-risk committee can read and challenge.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT SHIPPED Rendered as markdown and one HTML file a reviewer opens with no app. WP67

IMPLEMENTED BY mechanism:governance/safety-case; mechanism:governance/assurance-pack; artefact:safety-case; artefact:assurance-pack

- SOURCES
- UK AI Security Institute and partners, *Safety cases for frontier AI* (2025).
 - Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).
 - OWASP CycloneDX, *CycloneDX AI/ML bill of materials* (2024).

51 Incident reporting

SHIPPED

incident-reporting

SUB-CATEGORY Assurance MATURITY Widely adopted POINTS —

What went wrong, when, and what the bot saw and decided at that tick.

What went wrong, when, and what the bot saw and decided at that moment, recorded so the incident can be understood, reported and learned from. The AI Incident Database and the OECD monitor set the public expectation; NIST's AI RMF makes it a management function.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT SHIPPED Each incident's findings carry the decision explained. WP49

IMPLEMENTED BY mechanism:governance/incidents; mechanism:governance/explain; artefact:incident-log

SOURCES

- Responsible AI Collaborative; OECD, *AI Incident Database*; *OECD AI incidents monitor* (2024).
- NIST, *AI Risk Management Framework (AI RMF 1.0)* (2023).

52 Control-effectiveness measurement

SHIPPED

control-effectiveness

SUB-CATEGORY Assurance MATURITY Emerging POINTS —

An experiment that says which control changed what, by how much, and how sure.

An experiment that says which control changed which outcome, by how much, and with what confidence — the difference between believing a guardrail works and knowing that it does. PRA SS1/23 asks a bank to evidence its model controls in exactly this way.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT SHIPPED The register joins a stack's controls since WP97. WP90

IMPLEMENTED BY mechanism:evals/experiment; mechanism:governance/control-effectiveness

SOURCES

- Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).
- NIST, *AI Risk Management Framework (AI RMF 1.0)* (2023).

53 Fairness and parity measurement

SHIPPED

fairness-and-parity

SUB-CATEGORY Evaluation MATURITY Widely adopted POINTS —

Outcomes compared across cohorts with intervals, on a matched pair where the design allows.

Outcomes compared across cohorts — for instance across the proxies for protected characteristics in lending — with confidence intervals, and where the design allows on a matched pair of cases that differ only in the cohort. A parity gate fails a run when the gap exceeds a declared threshold.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT SHIPPED Matched pairs on the lending, disputes and collections desks; age bands on fraud and collections. WP61

IMPLEMENTED BY mechanism:metrics/fairness; gate:parity; policy-card:fs-lending/policy/cohort-blind

SOURCES

- Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).
- ISO/IEC, *ISO/IEC 42001:2023 — AI management systems* (2023).

54 Governance frameworks and management systems

SHIPPED

governance-frameworks

SUB-CATEGORY Framework MATURITY Widely adopted POINTS —

NIST AI RMF, ISO/IEC 42001, the EU AI Act and SS1/23 as the vocabulary the control map speaks.

The management-system standards and regulations — NIST AI RMF and its generative-AI profile, ISO/IEC 42001, the EU AI Act, PRA SS1/23 — used as the vocabulary a control map speaks, so every control can be pointed at the obligation it serves. A reference posture, and in Craft A Bot explicitly not a compliance claim.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT SHIPPED A reference posture, not a compliance claim (08-... §6). WP67

IMPLEMENTED BY mechanism:governance/control-maps

- SOURCES
- NIST, *AI Risk Management Framework (AI RMF 1.0)* (2023).
 - NIST, *AI 600-1: Generative AI Profile* (2024).
 - ISO/IEC, *ISO/IEC 42001:2023 — AI management systems* (2023).
 - European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 9, 12, 13 and 14* (2024).
 - Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).

55 Calibration monitoring

SHIPPED

calibration-monitoring

SUB-CATEGORY Evaluation MATURITY Widely adopted POINTS —

Whether a reader's stated confidence matches how often it is right — reliability, ECE, Brier — over an answer key.

A model that says it is 90% sure should be right about nine times in ten. Calibration monitoring checks that: over an answer key, it plots stated confidence against observed accuracy (the reliability diagram) and summarises the gap as expected calibration error and the Brier score. It matters because every confidence gate and every risk-tiered routing downstream assumes the number means something; a classifier that is confidently wrong defeats them silently. PRA SS1/23 expects a bank to monitor a model's performance in use, and calibration is the measure that tells whether its self-reported certainty can be trusted.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT SHIPPED The calibration pane on any report with readings and an answer key; the figures validated against the branch's published ones. WP118

IMPLEMENTED BY mechanism:metrics/calibration

- SOURCES
- Guo, Pleiss, Sun and Weinberger (ICML), *On calibration of modern neural networks* (2017).
 - Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).

56 Model inventory and change control

SHIPPED

model-change-control

SUB-CATEGORY Assurance MATURITY Widely adopted POINTS —

The model, stack, settings and prompt a bot runs with pinned and digested, and a change read before it runs.

The model, the stack, the settings and the prompt a bot runs with are pinned and digested as one build, the build that was validated is named, and a run on any other build is read before it is trusted. This is the model inventory and change control that PRA SS1/23 asks for, extended to the parts of an agent that are not the model — a changed threshold or a swapped guard is a model change in its effect. The EU AI Act's obligations on providers and deployers assume the same: you can say which version did what, and a change went through a process.

PROTECTS AGAINST ASI04 Agentic supply-chain vulnerabilities

IN CRAFT A BOT **SHIPPED** A build digest over the goal card and its dial (the knobs) and every brick's kind and config (the cartridge, the personality, the stack) is on every exported kit file (WP147); a host that names the build it validated gets run.started.changed when a run is of another; a knob a shipped campaign or experiment sets is a reading on the reading desk, read like a calibration row; the bank's model-change-control row cites them with the no-regression gate. The packs a bot is built from are pinned by their own digest (WP141). Not done: nothing yet stores a validated digest for the Workbench's own bots — the harness names it with run --validated. WP147

IMPLEMENTED BY mechanism:core/build-digest ; mechanism:core/agent-card ; mechanism:core/kit-requires ; mechanism:core/cassette-digest ; mechanism:core/pack-digest ; gate:no-regression

SOURCES

- Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).
- NIST, *SP 800-53 Rev. 5 — Security and privacy controls (AC-6 least privilege, CM-3 change control, SC-24 fail in known state)* (2020).
- European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 15, 26 and 86* (2024).

57 Shadow running

SHIPPED

shadow-mode

SUB-CATEGORY Assurance MATURITY Widely adopted POINTS —

A control or a model run beside the live path on real traffic, its verdicts recorded and never applied, before it is trusted.

A new control or model runs beside the live path on real traffic, its verdicts recorded and compared but never applied, until there is evidence to trust it. Google's ML Test Score rubric lists it among the basics of production readiness; PRA SS1/23 expects a model to be validated in conditions like those it will meet. For a guardrail it is the only way to learn the false-alarm rate on genuine customer traffic before the alarms start stopping genuine customers — and to put a number on what enforcement would have cost.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT **SHIPPED** The Gate runs a stack over an agent's live traffic and records every verdict without applying one, and a campaign guard in mode shadow does the same over a campaign (WP149): every verdict that would block, stop, pause, redact or mark is an annotation saying so, and the run goes on. The shadow covers a guard's components and stack; the Safety and Guard bricks a guard fits are not shadowed. WP127

IMPLEMENTED BY mechanism:gate/shadow ; mechanism:evals/shadow-guard

SOURCES

- Breck, Cai, Nielsen, Salib and Sculley (Google), *The ML Test Score: a rubric for ML production readiness and technical debt reduction* (2017).
- Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).

Human oversight

Where a person sits in the loop — approvals, second signatures, the stop button, the case handed over when a model is unsure or a deadline passes — the customer’s own routes to a person (vulnerability, appeal), and the measures that show whether that oversight is real or has become a rubber stamp.

Human in the loop 6 · Interruptibility 1 · Autonomy 1 · Explainability 1 · Customer outcomes 1 · Contestability 1 · Escalation 1

58 Risk-tiered approval

SHIPPED

risk-tiered-approval

SUB-CATEGORY Human in the loop MATURITY Widely adopted POINTS pre-act

A person asked before a risky action, with the tiers declared by the world.

A person is asked before a risky action, with the risk tiers declared by the world the bot acts in (reversible, irreversible). The approval mode chooses whether everything, only the irreversible, or nothing needs a person — and the choice is recorded with the run.

PROTECTS AGAINST ASI02 Tool misuse and exploitation; ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED Approval on everything or on what is reversible or irreversible, as the world declares.
WP24

IMPLEMENTED BY governance/approval-mode; mechanism:core/risk-tier

- SOURCES
- Vercel, *AI SDK — policy-based tool approvals* (2025).
 - OpenAI, *Agents SDK guardrails and AgentKit* (2025).
 - European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 9, 12, 13 and 14* (2024).

59

Four-eyes and decision-rights ceilings

SHIPPED

four-eyes

SUB-CATEGORY Human in the loop MATURITY Widely adopted POINTS stage-in

A second person on an irreversible decision, and a ceiling on what a bot may decide alone by autonomy level.

A second person on an irreversible decision, and a ceiling — by autonomy level — on what a bot may decide alone: an amount, a decision type, a customer segment. Banking’s oldest control, expressed as a human stage in the workflow and a table of decision-rights limits.

PROTECTS AGAINST ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED Workflow content and cards, not a component: a human stage and a four-eyes card on every desk’s irreversible act, and a ceiling per decision right by level. The ceilings are measured by default — a breach rate on every report; since WP139 a configuration that sets ‘autonomy.enforce’ holds a decision above its ceiling for a person where it is recorded. The reference configurations measure. WP80

IMPLEMENTED BY mechanism:workflow/human-stage ; mechanism:workflow/autonomy-ceilings ; policy-card:fs-lending/policy/disbursement-is-four-eyes ; policy-card:fs-fraud/policy/freeze-needs-a-second-look ; policy-card:fs-advice/policy/four-eyes-on-execution ; policy-card:fs-onboarding/policy/open-is-four-eyes ; policy-card:fs-disputes/policy/reimbursement-is-four-eyes ; policy-card:fs-collections/policy/a-plan-is-four-eyes ; policy-card:fs-servicing/policy/closure-is-four-eyes

SOURCES

- Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).
- European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 9, 12, 13 and 14* (2024).

60

Kill switch and safe-mode degradation

SHIPPED

kill-switch

SUB-CATEGORY Interruptibility MATURITY Widely adopted POINTS pre-think

A person can stop any run; a degraded model falls back to a plain sentence rather than a guess.

A person can stop any run at any time, and a degraded model (a provider fault, a timeout) falls back to a plain safe sentence rather than a guess. Shutdown resistance is a named frontier-safety concern; the practical control is that stop always works and the fallback is never an invention.

PROTECTS AGAINST ASI10 Rogue agents; ASI08 Cascading failures

IN CRAFT A BOT SHIPPED Stop is the session’s; the Fallback card is a policy card fitted on every desk; a provider fault is an injection the incident decks judge. WP72

IMPLEMENTED BY governance/policy-card ; mechanism:core/stop ; mechanism:core/provider-fault ; policy-card:fs-bank/policy/fallback ; evaluator:fs-bank/told-plainly

SOURCES

- Google DeepMind, *Frontier Safety Framework v3 (shutdown resistance)* (2025).
- CISA and partner agencies, *Multi-agency guidance on securing agentic AI* (2026).

61 Levels of autonomy

SHIPPED

autonomy-levels

SUB-CATEGORY Autonomy MATURITY Emerging POINTS —

What a bot may decide alone, by level, with the touches a person makes counted per case.

A declared level of autonomy — what a bot may decide on its own — with the touches a person makes counted per case, so the level a bank claims can be checked against the level it actually runs at. The counting is what separates a policy statement from a measurement.

PROTECTS AGAINST ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED Touches per case, unattended rate and ceiling breaches on every report. A level's ceilings are measured by default, and enforced — a person confirms what is above them — where a configuration sets `autonomy.enforce` (WP139). WP80

IMPLEMENTED BY mechanism:workflow/autonomy-ceilings; mechanism:metrics/human-load

SOURCES

- arXiv; Knight First Amendment Institute, *Levels of AI agents; levels of autonomy for agentic systems* (2024).
- Anthropic, *Measuring autonomy in deployed agents* (2026).

62 Confirmation fatigue

SHIPPED

confirmation-fatigue

SUB-CATEGORY Human in the loop MATURITY Research POINTS —

Measuring how many approvals a person is asked for, so oversight is not theatre.

If a person is asked to approve too often they stop reading, and oversight becomes theatre. Counting approvals per case makes that visible; adaptive throttling — asking less where the person always says yes — is the research response, and carries its own risk.

PROTECTS AGAINST ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED Counted; no adaptive throttling. WP80

IMPLEMENTED BY mechanism:metrics/human-load

SOURCES

- arXiv, *Approval and confirmation fatigue in agent permissioning* (2025).
- Anthropic, *Measuring autonomy in deployed agents* (2026).

63 Explainability to end users

SHIPPED

explainability

SUB-CATEGORY Explainability MATURITY Widely adopted POINTS —

What the bot saw, was offered, chose and what checked it – and an explanation that names only real reasons.

What the bot saw, what it was offered, what it chose and what checked it — shown to the reviewer and, in plain terms, to the customer — with an explanation that names only real reasons, checked by a faithfulness evaluator. The EU AI Act and the Consumer Duty both expect an explanation a person can act on.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT SHIPPED Explain in the Run Lab; the faithfulness evaluator on the lending desk. WP66

IMPLEMENTED BY mechanism:governance/explain; evaluator:fs-lending/explanation-faithful

SOURCES

- European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 9, 12, 13 and 14* (2024).
- Financial Conduct Authority, *FCA Handbook — COBS 4 (financial promotions), COBS 9 (suitability), PRIN 2A (Consumer Duty)* (2023).

64 Confidence gating and abstention

SHIPPED

confidence-gate

SUB-CATEGORY Human in the loop MATURITY Emerging POINTS —

A judgment below its confidence threshold handed to a rule or a person instead of acted on.

A judgment made below a stated confidence threshold is not acted on; it goes to a rule or to a person instead. This is selective classification from the research literature — a model allowed to abstain is more accurate on what it does answer — turned into a routing control: the threshold decides how much of the work the model takes and how much a person sees. The EU AI Act’s Article 14 wants human oversight that is meaningful, and a gate makes the hand-over a rule rather than a hope; its value depends entirely on the confidence being calibrated, which is why the two controls are read together.

PROTECTS AGAINST ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED A reader stage below its threshold, or hearing a steer, goes to its else. Since WP138 the servicing, disputes and complaints journeys read on gated readers wherever those stages were rules, at the desks’ line of 0.8 with the bank’s rule as the else; the rule readers answer at confidence 1, so the gate fires only when a less certain reader is swapped in — which the optional TypeSafe journey does. WP117

IMPLEMENTED BY mechanism:workflow/reader-gate ; mechanism:metrics/calibration ; reader:fs-servicing/reader/category ; reader:fs-servicing/reader/support-need ; reader:fs-disputes/reader/classification ; reader:fs-advice/reader/root-cause

- SOURCES
- Geifman and El-Yaniv (NeurIPS), *Selective classification for deep neural networks* (2017).
 - European Union, *Regulation (EU) 2024/1689 (the AI Act), Article 14 (human oversight)* (2024).
 - Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).

65

Vulnerability detection and support

SHIPPED

vulnerability-detection

SUB-CATEGORY

Customer outcomes

MATURITY

Widely adopted

POINTS

pre-act

A sign that a customer is vulnerable noticed, recorded, and acted on – referral, forbearance, adjusted service.

A sign that a customer may be vulnerable — a bereavement mentioned in passing, a health condition, difficulty understanding, financial distress — is noticed at intake, recorded, and acted on: a referral, forbearance, a different pace of service. FCA FG21/1 and the Consumer Duty expect a firm to recognise vulnerability and respond to it, and an automated front door that cannot is a conduct failure however good its decisions are. The detection is a reader over the customer’s own words, so it can only see what the customer said; what is done with the finding is where the obligation actually lands.

PROTECTS AGAINST

ASI09

Human-agent trust exploitation

IN CRAFT A BOT

SHIPPED

Every journey’s intake stage asks the bank’s support-need reader, behind the desks’ line, whether the customer’s own words disclose a need, and records the finding at stage-in before anything is decided (WP145); the advice, collections and servicing desks act on and record it. The reader is a keyword rule — a measured model is the slot’s next step — and it can only read words the item carries: an alert or an application has none. WP60

IMPLEMENTED BY

policy-card:fs-advice/policy/vulnerability-means-refer; evaluator:fs-advice/vulnerability-actioned; evaluator:fs-collections/vulnerability-actioned; policy-card:fs-servicing/policy/record-a-disclosure; evaluator:fs-servicing/disclosure-recorded; component:fs-bank/guard/vulnerability-detection

SOURCES

- Financial Conduct Authority, *FG21/1 — Guidance for firms on the fair treatment of vulnerable customers* (2021).

66 Contestability and appeal

SHIPPED

contestability

SUB-CATEGORY Contestability MATURITY Widely adopted POINTS —

A customer told they can challenge an automated decision, a route to a person, and the appeal recorded and decided.

A customer subject to an automated decision is told they can challenge it, given a route to a person, and the appeal is recorded and decided by one. UK GDPR’s Article 22 grants the right; the EU AI Act’s Article 86 adds an explanation; DISP sets the route and the clock for a complaint. The practical control has three parts: the words that tell the customer (a declined loan’s reasons and review right, the Ombudsman in a final response), a hand-off from the deciding journey into the review one, and a person’s decision at the end of it — so that “you can appeal” is a path on the trace rather than a sentence in a letter.

PROTECTS AGAINST ASI09 Human-agent trust exploitation

IN CRAFT A BOT SHIPPED A contested decline on the lending, onboarding and disputes desks is handed to the bank’s one review journey, complaints, as a handoff of kind appeal (WP145): a person approves its outcome below Level 5, and the run records the handoff. The customer is told the route — the review right with a declined loan’s reasons, the Ombudsman with every final response — in registered words digested on the trace. The complaints journey’s own adverse decision is not handed on: its route out is the Ombudsman. WP145

IMPLEMENTED BY mechanism:workflow/appeal ; evaluator:fs-lending/appeal-handled ; evaluator:fs-lending/review-right-disclosed ; evaluator:fs-advice/ombudsman-disclosed

- SOURCES
- UK Parliament (Data Protection Act 2018 and the retained Regulation), *UK GDPR, Articles 5 (principles), 22 (automated decisions) and 25 (by design)* (2018).
 - European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 15, 26 and 86* (2024).
 - Financial Conduct Authority, *FCA Handbook — DISP 1 (complaint handling and its time limits)* (2024).

67 Timeliness and escalation by the clock

SHIPPED

timeliness

SUB-CATEGORY Escalation MATURITY Widely adopted POINTS —

A case past its deadline escalated to a person, with the regulator's timescales as the deadlines.

Every stage carries a deadline drawn from the regulator's timescales — DISP's acknowledgement and final-response limits for a complaint, the PSR's window for APP-scam reimbursement — and a case that passes its deadline is escalated to a person and counted as an incident. A bot that is accurate but slow still breaches, and a backlog is invisible until someone measures the clock. The control turns the regulator's calendar into a property of the journey, checked on every case rather than sampled at the quarter's end.

PROTECTS AGAINST — (an assurance measure rather than a defence against a named threat)

IN CRAFT A BOT **SHIPPED** A stage carries a deadline in journey ticks, citing its timescale (WP146): the complaints journey's acknowledgement and final response (DISP 1.6), the disputes journey's reimbursement (the PSR's, a stated mapping). A stage done past it is recorded overdue and written stage.overdue; the bank clock counts the case and lists it among the day's incidents — its escalation to a person; the timeliness gate holds a book to it. A tick is the simulator's unit, not a day: the deadlines are measured against the shipped configurations and stated as assumptions. WP146

IMPLEMENTED BY mechanism:workflow/deadlines ; trace-guarantee:stage.overdue ; gate:timeliness ; evaluator:fs-fraud/time-to-decision ; evaluator:fs-advice/complaint-acknowledged

SOURCES

- Financial Conduct Authority, *FCA Handbook — DISP 1 (complaint handling and its time limits)* (2024).
- Payment Systems Regulator, *Specific Requirement 1 — APP scam reimbursement* (2024).

68 Override reasons

SHIPPED

override-reason

SUB-CATEGORY Human in the loop MATURITY Widely adopted POINTS —

When a person overrules a bot's recommendation or waives a guard's refusal, the reason is on the record.

When a person overrules a bot's recommendation, or waives a guard's refusal, the reason they gave is on the record beside the decision. Without it an override is a number — so many per case — and the number cannot tell a careful reviewer from a hurried one. With it, a model-risk function can read why the model and the person disagreed, which is where both the model's and the reviewer's weaknesses show; the EU AI Act's Article 14 and PRA SS1/23 both assume human oversight that can be evidenced, and a reason is the evidence.

PROTECTS AGAINST **ASI09** Human-agent trust exploitation

IN CRAFT A BOT **SHIPPED** A person's decision against what the case recommended is recorded as an override on the approval and on approval.resolved, with the reason they gave (WP146); the override-reason gate holds a campaign to the share of overrides with a reason. Diverged: a gate, not an evaluator — an agent run's evaluator cannot see a journey's human stage. Not required by the runtime: an override without a reason is recorded as such, which is what the gate counts, rather than refused. The fallible reviewer model gives no reasons, so a campaign over it reads the gate failing — a true finding about a model of a person, not a person. WP146

IMPLEMENTED BY trace-guarantee:approval.resolved ; mechanism:core/principal ; mechanism:workflow/override-reason ; gate:override-reason

SOURCES

- European Union, *Regulation (EU) 2024/1689 (the AI Act), Article 14 (human oversight)* (2024).
- Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023).

69

Adaptive approval

SHIPPED

adaptive-approval

SUB-CATEGORY

Human in the loop

MATURITY

Research

POINTS

pre-act

The approval tier raised or lowered as a person’s approvals per case climb, so oversight does not become rubber-stamping.

The approval tier is raised or lowered as a person’s approvals per case climb: ask about everything at first, then only about what changes the world, then only about what cannot be undone, so that oversight does not decay into rubber-stamping. It answers confirmation fatigue directly — if the person will say yes to everything, asking about everything protects nothing. A research idea still, with an obvious hazard: the tier is lowered precisely when the person is least attentive, so the floor (what is never waved through) matters more than the schedule.

PROTECTS AGAINST

ASI09

Human-agent trust exploitation

IN CRAFT A BOT

SHIPPED

The approval mode’s adaptive setting asks a person about every action until fatigueAfter approvals have been asked in the run, then only about what changes the world, and after twice that only about what cannot be undone (WP149); approvals per case are counted on every report, the confirmation fatigue it answers. The count is read from the trace, so a fork asks the same. No shipped configuration sets it: what a desk should ask a person about is a reading for Andrew. WP149

IMPLEMENTED BY

governance/approval-mode

SOURCES

- arXiv, *Approval and confirmation fatigue in agent permissioning* (2025).

What the product does not claim

Two lists the catalogue keeps on purpose, so that a reader never has to infer the absence of a control.

Blueprint – described and mapped, nothing built

- **Formal verification of agent policies** — Recorded as research: proving a policy over every possible action is not built. Bedrock's automated-reasoning checks, which check one answer's claims against rules as logic, are their own entry (automated-reasoning-checks, connectable since WP144).

Not applicable – said, with the reason

- **Rate limits** — Not applicable to a simulator: a run has no wall clock a rate could be measured against — the budgets are the bound, and a provider's own limit reaches the trace as `provider.retry`.
- **Guardrail frameworks** — Not applicable as a dependency: the guard shell (29-...) and the component contract (85-...) are the product's own framework; a vendor framework's validators reach it as a service, not as rails.
- **Retention and deletion** — Not applicable: the product is local-first and retains nothing on anyone's behalf — every record is synthetic and stays in the user's own browser or folder until they delete it.
- **Access control on the controls** — Not applicable: there is no tenancy — one person runs the toolkit on their own machine; a change to a control is recorded (readings, the principal), never authorised.
- **Sandboxed tool and code execution** — Not applicable: the world is the sandbox — a bot performs declared actions on a simulated world and runs no code; recorded so the claim is not implied.
- **Content credentials on outputs** — Not applicable: a bot here says text to a simulated customer and makes no media; what it said is on the digested trace instead.

Threat codes

The codes the entries cite. The ASI series is the OWASP Top 10 for Agentic Applications (2026 edition); the LLM series is the OWASP Top 10 for LLM Applications 2025. Codes not cited by any entry are listed in grey for completeness.

CODE	THREAT	ENTRIES
ASI01	Agent goal hijack	01, 02, 04, 05, 14, 30, 34, 49
ASI02	Tool misuse and exploitation	06, 12, 13, 14, 23, 27, 31, 34, 58
ASI03	Identity and privilege abuse	13, 15, 22, 35, 36, 40
ASI04	Agentic supply-chain vulnerabilities	06, 42, 43, 46, 56
ASI05	Unexpected code execution	11, 12, 41
ASI06	Memory and context poisoning	05, 07, 19, 24
ASI07	Insecure inter-agent communication	30, 33, 37
ASI08	Cascading failures	16, 17, 18, 20, 21, 23, 26, 28, 33, 44, 45, 60
ASI09	Human-agent trust exploitation	03, 04, 08, 09, 10, 25, 47, 49, 58, 59, 61, 62, 64, 65, 66, 68, 69
ASI10	Rogue agents	20, 22, 35, 60
LLM01	Prompt injection	01, 02, 05, 06, 32
LLM02	Sensitive information disclosure	08, 19, 24, 36, 38, 39, 42
LLM03	Supply chain	—
LLM04	Data and model poisoning	—
LLM05	Improper output handling	03, 11, 27, 32
LLM06	Excessive agency	12
LLM07	System prompt leakage	46
LLM08	Vector and embedding weaknesses	—
LLM09	Misinformation	10, 29
LLM10	Unbounded consumption	26

Sources

Every source the edition cites — 79 in all — with the entries that cite it. Gathered in August 2026 for the AI-safety and governance reference (`19-AI-SAFETY-GOVERNANCE-REFERENCE.md`); a URL is on the content where the reference has one.

- Anthropic, *Constitutional Classifiers: defending against universal jailbreaks* (2025). Entries 02
- Anthropic, *Claude Code permissions and sandboxing* (2025). Entries 12, 41, 42
- Anthropic, *SHADE-Arena: evaluating sabotage and monitoring in LLM agents* (2025). Entries 20, 49
- Anthropic, *Petri: automated auditing of model behaviour* (2025). Entries 49
- Anthropic, *Measuring autonomy in deployed agents* (2026). Entries 61, 62
- Arize, *OpenInference — GUARDRAIL and agent spans* (2025). Entries 22
- arXiv, *AirGapAgent: protecting privacy with context hijacking* (2024). Entries 30
- arXiv, *Memory-poisoning attacks on LLM agents (2025–26 research)* (2025). Entries 07
- arXiv, *FIDES: information-flow control for LLM agents* (2025). Entries 19
- arXiv, *ShieldAgent: shielding agents via verifiable safety policy reasoning* (2025). Entries 31
- arXiv, *Approval and confirmation fatigue in agent permissioning* (2025). Entries 62, 69
- arXiv 2504.11703, *Progent: programmable privilege control for LLM agents* (2025). Entries 14, 15
- arXiv; Knight First Amendment Institute, *Levels of AI agents; levels of autonomy for agentic systems* (2024). Entries 61
- AWS, *Amazon Bedrock Guardrails (prompt-attack filter, automated reasoning checks)* (2025). Entries 01, 10, 31
- AWS, *Cedar policy language; Bedrock AgentCore gateway policies* (2025). Entries 13, 34
- AWS, *Amazon Bedrock Guardrails — automated reasoning checks* (2025). Entries 29
- AWS, Google and the sandbox vendors, *Firecracker microVMs and gVisor for agent code execution (E2B, Daytona)* (2025). Entries 41
- Breck, Cai, Nielsen, Salib and Sculley (Google), *The ML Test Score: a rubric for ML production readiness and technical debt reduction* (2017). Entries 57
- CISA and partner agencies, *Multi-agency guidance on securing agentic AI* (2026). Entries 33, 36, 42, 44, 60
- CNCF, *Open Policy Agent and Rego* (2024). Entries 13
- CNCF, *SPIFFE/SPIRE workload identity* (2024). Entries 35
- Coalition for Content Provenance and Authenticity, *C2PA content credentials specification* (2024). Entries 43, 47
- E. S. Page, Biometrika; agent observability guidance, *Page–Hinkley and behavioural drift detection on agent telemetry* (1954). Entries 21
- European Union, *Regulation (EU) 2022/2554 — the Digital Operational Resilience Act* (2022). Entries 45
- European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 9, 12, 13 and 14* (2024). Entries 22, 54, 58, 59, 63
- European Union, *Regulation (EU) 2024/1689 (the AI Act), Articles 15, 26 and 86* (2024). Entries 56, 66
- European Union, *Regulation (EU) 2024/1689 (the AI Act), Article 14 (human oversight)* (2024). Entries 64, 68
- Financial Conduct Authority, *FG21/1 — Guidance for firms on the fair treatment of vulnerable customers* (2021). Entries 65

- Financial Conduct Authority, *FCA Handbook — COBS 4 (financial promotions), COBS 9 (suitability), PRIN 2A (Consumer Duty)* (2023). Entries 09, 63
- Financial Conduct Authority, *FCA Handbook — COBS 4 (financial promotions) and COBS 9 (suitability)* (2023). Entries 25
- Financial Conduct Authority, *FCA Handbook — CONC 5 (creditworthiness) and CONC 7 (arrears, default and recovery)* (2023). Entries 25
- Financial Conduct Authority, *FCA Handbook — DISP 1 (complaint handling and its time limits)* (2024). Entries 66, 67
- Geifman and El-Yaniv (NeurIPS), *Selective classification for deep neural networks* (2017). Entries 64
- GitHub, *Secret scanning and push protection* (2024). Entries 38
- Google and IBM, *ShieldGemma and Granite Guardian model cards* (2024). Entries 03
- Google and the Linux Foundation, *Agent2Agent (A2A) protocol* (2025). Entries 37
- Google Cloud, *Model Armor documentation (filter version 3)* (2026). Entries 01, 02, 03, 08
- Google DeepMind, *Defeating prompt injections by design (CaMeL)* (2025). Entries 05, 19, 30
- Google DeepMind, *Frontier Safety Framework v3 (shutdown resistance)* (2025). Entries 60
- Guardrails AI, *Guardrails AI validators and hub* (2025). Entries 08, 10, 11, 32
- Guo, Pleiss, Sun and Weinberger (ICML), *On calibration of modern neural networks* (2017). Entries 55
- ICSE (arXiv 2503.18666), *AgentSpec: customizable runtime enforcement for safe and reliable LLM agents* (2026). Entries 14, 23
- Information Commissioner's Office, *Guidance on AI and data protection* (2023). Entries 24
- ISO/IEC, *ISO/IEC 42001:2023 — AI management systems* (2023). Entries 53, 54
- Lakera, *Lakera Guard documentation* (2025). Entries 01
- LangChain, *LangGraph recursion limits and time-travel debugging* (2025). Entries 16, 17
- M. Nygard (Pragmatic Bookshelf, 2nd edition), *Release It! — stability patterns: timeouts, circuit breakers, fail fast* (2018). Entries 28, 44, 45
- Meta, *Llama Guard 4 and Prompt Guard 2 model cards* (2025). Entries 01, 02, 03
- Microsoft, *Presidio — data protection and de-identification* (2024). Entries 08
- Microsoft, *Azure AI Content Safety — Prompt Shields and harm categories* (2025). Entries 01, 02, 03
- Microsoft, *Agent Governance Toolkit — OPA, Rego and Cedar policies for agents* (2025). Entries 13, 34
- Microsoft, *Microsoft Entra Agent ID* (2025). Entries 35
- Microsoft Research, *Defending against indirect prompt injection with spotlighting* (2024). Entries 05
- MITRE, *MITRE ATLAS (agentic techniques, 2025–26 updates)* (2025). Entries 06
- Model Context Protocol, *MCP security best practices* (2025). Entries 06, 36
- NIST, *SP 800-53 Rev. 5 — Security and privacy controls (AC-6 least privilege, CM-3 change control, SC-24 fail in known state)* (2020). Entries 40, 44, 56
- NIST, *AI Risk Management Framework (AI RMF 1.0)* (2023). Entries 51, 52, 54
- NIST, *AI 600-1: Generative AI Profile* (2024). Entries 54
- NVIDIA, *NeMo Guardrails* (2024). Entries 32
- Okta, *Cross App Access (XAA) and OAuth extensions for agents* (2025). Entries 35
- OpenAI, *The Instruction Hierarchy: training LLMs to prioritise privileged instructions* (2024). Entries 05
- OpenAI, *Moderation API and gpt-oss-safeguard* (2025). Entries 03, 04
- OpenAI, *Agents SDK guardrails and AgentKit* (2025). Entries 11, 12, 16, 18, 32, 58
- OpenTelemetry, *OpenTelemetry semantic conventions for generative AI* (2025). Entries 21, 22
- OWASP CycloneDX, *CycloneDX AI/ML bill of materials* (2024). Entries 43, 50
- OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications (2026 edition)* (2025). Entries 01, 06, 07, 20, 23, 27, 28, 33, 37, 43
- OWASP GenAI Security Project, *OWASP Top 10 for LLM Applications 2025* (2025). Entries 01, 26, 27, 38, 46
- OWASP GenAI Security Project, *Agentic AI — Threats and Mitigations* (2025). Entries 15

- Payment Systems Regulator, *Specific Requirement 1 — APP scam reimbursement* (2024). Entries 25, 67
- Prudential Regulation Authority, *SS1/21 — Operational resilience: impact tolerances for important business services* (2021). Entries 45
- Prudential Regulation Authority, *SS1/23 — Model risk management principles for banks* (2023). Entries 50, 52, 53, 54, 55, 56, 57, 59, 64, 68
- Responsible AI Collaborative; OECD, *AI Incident Database; OECD AI incidents monitor* (2024). Entries 51
- Sierra (arXiv), *τ -bench: a benchmark for tool-agent-user interaction* (2024). Entries 48
- Simon Willison, *The lethal trifecta for AI agents; the dual-LLM pattern* (2025). Entries 19, 30
- UK AI Security Institute, *Inspect evaluation framework* (2024). Entries 10, 48
- UK AI Security Institute and partners, *Safety cases for frontier AI* (2025). Entries 50
- UK Parliament, *Proceeds of Crime Act 2002, s.333A (tipping off)* (2002). Entries 09
- UK Parliament (Data Protection Act 2018 and the retained Regulation), *UK GDPR, Articles 5 (principles), 22 (automated decisions) and 25 (by design)* (2018). Entries 24, 39, 66
- Vercel, *AI SDK — policy-based tool approvals* (2025). Entries 12, 58